

Análisis Forense Informático

Unidad 12. Análisis Forense de Correo Electrónico



Índice

1	Introducción.....	2
2	Consideraciones legales.....	2
3	Fundamentos del correo electrónico	3
4	Metodología de análisis forense de correos electrónicos	5
5	Donde hacer el análisis del correo.....	6
6	Partes de un correo electrónico.....	6
7	Análisis de la cabecera de correo.....	9
7.1	Campo RECEIVED	10
7.2	Campo MESSAGE ID.....	10
7.3	Campo MAPI HEADERS	11
7.4	Campo CONTENT LENGTH.....	12
7.5	Protocolos de Autenticación	12
7.5.1	Situación actual	13
7.5.2	DKIM (DomainKeys Identified Mail)	13
7.5.3	SPF	15
7.5.4	DMARC.....	16
7.5.5	AUTHENTICATION RESULTS	18
8	Funcionamiento de los protocolos de autenticación	19
8.1	SPF (Sender Policy Framework)	19
8.2	Ejemplo análisis forense SPF email phishing.....	20
8.3	DKIM (Domainkeys Identifier Mail)	20
8.4	Ejemplo análisis forense DKIM email phishing	22
8.5	DMARC (Domain-based Message Authentication).....	22
8.5.1	DMARC Alignment (alineación de dominios)	23
8.5.2	Flujo completo SPF + DKIM + DMARC.....	23
9	Ejemplos de analisis forense SPF/DKIM/DMARC	24
9.1	Caso 1: Phishing AEAT - Campaña 2026 (420,000 emails)	24
9.2	Caso 2: BEC (Business Email Compromise) - Fraude €120K	27
10	Buscando evidencias de correos electrónicos	28
10.1	Microsoft Outlook PST	28
10.2	Thunderbird MBOX.....	29
10.3	Google Takeout	31
11	Coherencia de la cabecera y los metadatos.....	31
11.1	Coherencia en la cabecera.....	31
11.2	Coherencia de aplicaciones	32
11.3	Metadatos de adjuntos	32

12	Herramientas útiles.....	33
12.1	MXTOOLBOX	33
12.2	DMARCIAN (Análisis DMARC avanzado)	34
12.3	Google Admin Toolbox (toolbox.googleapps.com)	35

1 Introducción.

El correo electrónico es hoy en día uno de los métodos más populares en las comunicaciones entre empresas. Es por ello, que frecuentemente se requieren los servicios de un perito informático en los casos en que se deba realizar un análisis de estos para presentar un informe en un proceso judicial.



Es importante destacar que **es un sistema de comunicación NO FIABLE**. Es muy sencillo hacerse pasar por otra persona y hacer creer que se está enviando un correo desde otra cuenta.

Los ataques habituales en los que interviene el correo son:

- Publicidad engañosa (Spamming).
- Ataques Phishing.
- Búsqueda de información confidencial
- Archivos maliciosos (malware)
- Ataques de ransomware

La información que se puede encontrar al analizar un email es:

- **¿Quién envió el email?** -> Dirección de correo, dirección IP, pruebas de contexto.
- **¿Cuándo fue enviado?** -> Timestamp en la cabecera y el timestamp de los servidores.
- **¿Desde donde fue enviado?** -> Dirección IP/ISP, Geolocalización, Mail server domain, Message ID
- **¿Es el contenido relevante?** -> Message Body, adjuntos, libreta de direcciones, entradas de calendario....

2 Consideraciones legales

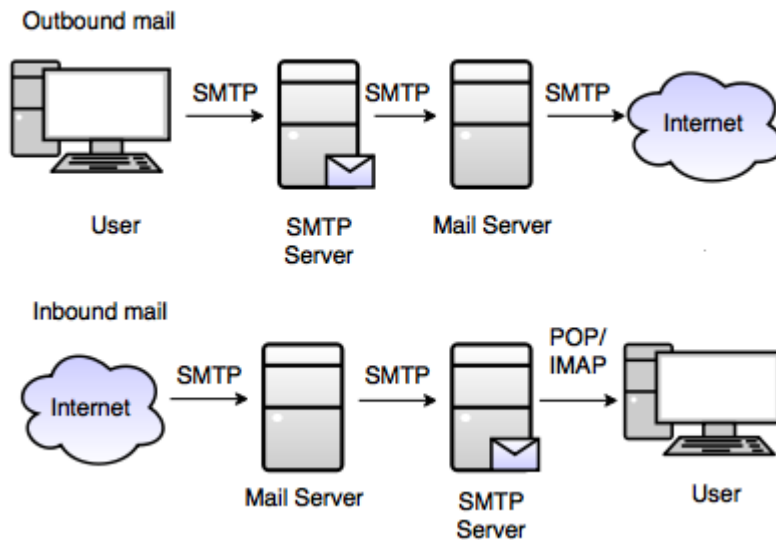
Un correo electrónico al igual que un correo ordinario está protegido por el Derecho de la Intimidad y, por tanto, no puede ser abierto por lo general por alguien que no sea propietario del mismo.

Aunque una cuenta de correo electrónico esté configurada en un ordenador de la empresa, **los gerentes o jefes de la empresa no pueden acceder a los correos de una cuenta electrónica personal**. Aun siendo una **cuenta de correo corporativa, el acceso a la misma puede estar protegido por este Derecho**. Antes de acceder se recomienda pedir autorización.

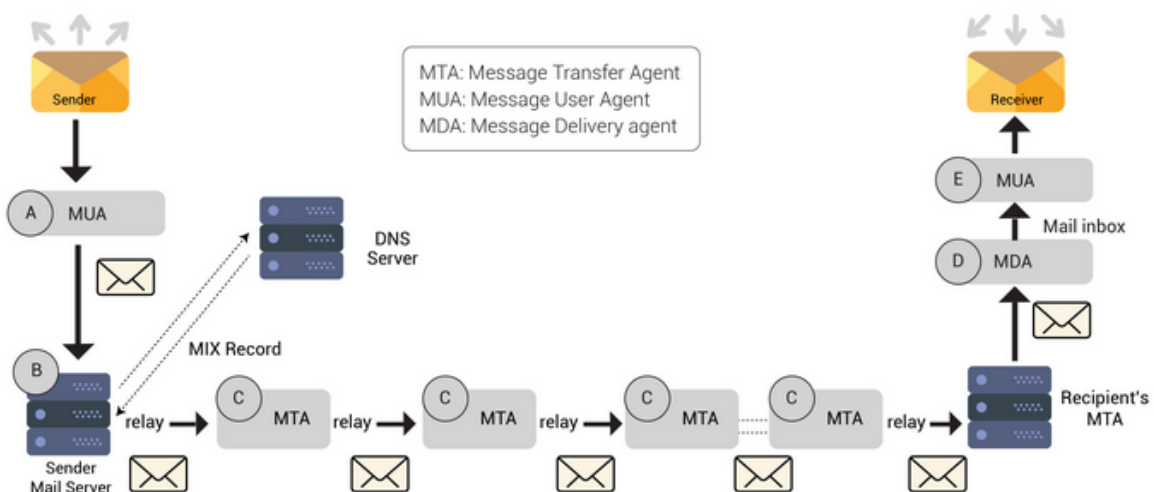
Un correo electrónico impreso no significa prácticamente nada. Esta prueba siempre estaría condicionada por la impugnación de la otra parte.

3 Fundamentos del correo electrónico

- Ruta típica de un correo electrónico:



- Elementos típicos en un flujo de correo electrónico.



Sender's Mail/Message User Agent (MUA)

MUA, también conocido como cliente de correo electrónico, es una aplicación informática que permite redactar y enviar correos electrónicos, o recibir y leer los que se le envían. MUA puede ser un cliente web, lo que significa que permite enviar y recibir correos electrónicos a través del navegador (p. ej., Gmail, Yahoo en Firefox, Chrome, etc.) o puede ser un cliente basado en aplicaciones (p. ej., Thunderbird, Outlook, etc.). Para enviar un correo electrónico, el remitente debe redactarlo, añadir el nombre del destinatario y hacer clic en el botón "Enviar".

Sender's Email Server

Una vez que el remitente ha redactado y enviado un correo electrónico, un servidor de correo electrónico está listo para recibirlo y procesarlo. **El servidor de correo electrónico es una aplicación informática que escucha en los puertos 25 (sin cifrar), 465 (SSL/TLS) y 587 (STARTTLS).** El servidor de correo electrónico recibe el correo electrónico del remitente y lo reenvía para su entrega. Todos los correos electrónicos salientes se colocan en una cola de correo y, en paralelo, el servidor SMTP consulta el registro MX del servidor DNS para averiguar la ubicación del servidor de correo electrónico del destinatario. Una vez que encuentra la dirección IP del servidor de correo electrónico del destinatario, envía el mensaje redactado a esa IP. **Por ejemplo, el registro MX para xyz.com sería mail1.xyz.com.**

En la cola de correo electrónico, el servidor SMTP busca la validación del registro MX y del destinatario. Si el servidor no puede procesar el correo, lo coloca en una cola diferida, que no se entregará inmediatamente, y reintenta después de un tiempo varias veces antes de enviar la confirmación fallida al cliente. Si está validado y se destina a entrega local, lo transfiere al agente de entrega local; si se destina a entrega remota, contacta con otros servidores de correo para su retransmisión.

Mail/Message Transfer Agent (MTA)

Si ese correo electrónico está destinado a entrega remota, lo retransmitirá a un MTA. **Un MTA es una aplicación de software que retransmite correo electrónico de un nodo a otro mediante el protocolo SMTP. El MTA recibe el correo electrónico de otro MTA o un MUA.** Tras recibirlo, añade la etiqueta "recibido" al principio del archivo de encabezado del mensaje y lo retransmite a otro MTA para su posterior entrega. También se conoce como agente de retransmisión de correo electrónico. El MTA procesa cada correo, realiza un seguimiento de cada actividad y analiza la lista de destinatarios para las acciones de enrutamiento. Envía respuestas de no entrega cuando un mensaje no llega a su destino. Algunos MTA de código abierto son Exim, Postfix, etc.

Mail/Message Delivery Agent (MDA)

MDA es una aplicación de software que recibe el correo del MTA y se encarga de entregarlo al buzón del destinatario. Tras la entrega final, se añade el campo "Ruta de retorno" al sobre para registrar la ruta de retorno. Algunos MDA de código abierto populares son Dovecot, Fetchmail, etc.

Recipient Mail/Message User Agent (MUA)

MUA es una aplicación de software que obtiene el correo electrónico del servidor POP3 o del servidor IMAP y carga ese correo electrónico desde el buzón del usuario al cliente de correo electrónico (es decir, Thunderbird, Outlook).

El servidor POP3 escucha en los siguientes puertos:

- Puerto 110 – Protocolo de oficina postal para correo no cifrado.
- Puerto 995 – Protocolo de oficina postal sobre SSL/TLS.

El servidor IMAP escucha en los siguientes puertos:

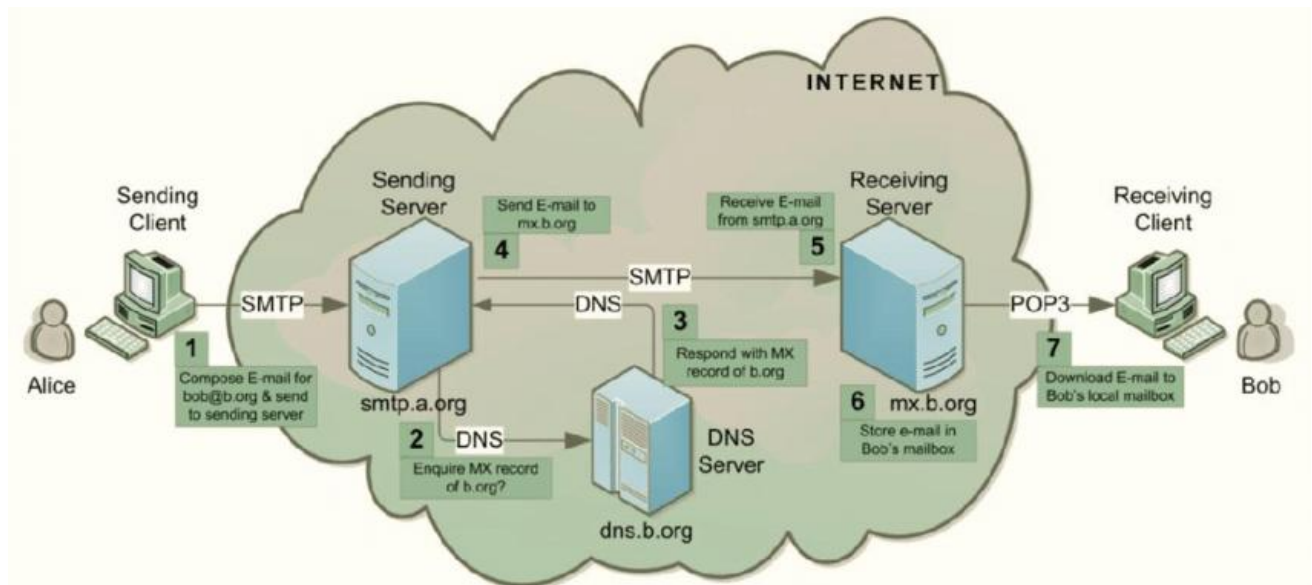
- Puerto 143 – Protocolo de acceso a mensajes de Internet para correo no cifrado.
- Puerto 993 – Protocolo de acceso a mensajes de Internet sobre SSL/TLS.

En pocas palabras, el agente de transporte de correo (MTA), como Postfix o Exim, es responsable de enviar el correo electrónico al destino correcto y entregarlo al MDA.

El agente de entrega de correo (MDA), como Dovecot, Fetchmail, recibe correo del MTA y lo envía al buzón del usuario. (Dovecot admite los protocolos POP3 e IMAP junto con la funcionalidad MDA).

El Agente de Usuario de Correo (MUA), como Thunderbird o Outlook, es el cliente de correo electrónico que obtiene el correo electrónico de los buzones del usuario y se lo presenta.

El envío de correo electrónico con más detalle:



4 Metodología de análisis forense de correos electrónicos

- Asegurar acceso lícito.
- Identificar herramientas necesarias.
- Identificación de correos.
- Pertenencia
- Extracción de datos (correo y encabezados)
- Autenticidad e Integridad
- Análisis de encabezados.
- Identificación de participantes.
- Origen (servidores)
- Cuentas y si es posible, sus titulares.
- Informe y conclusiones.

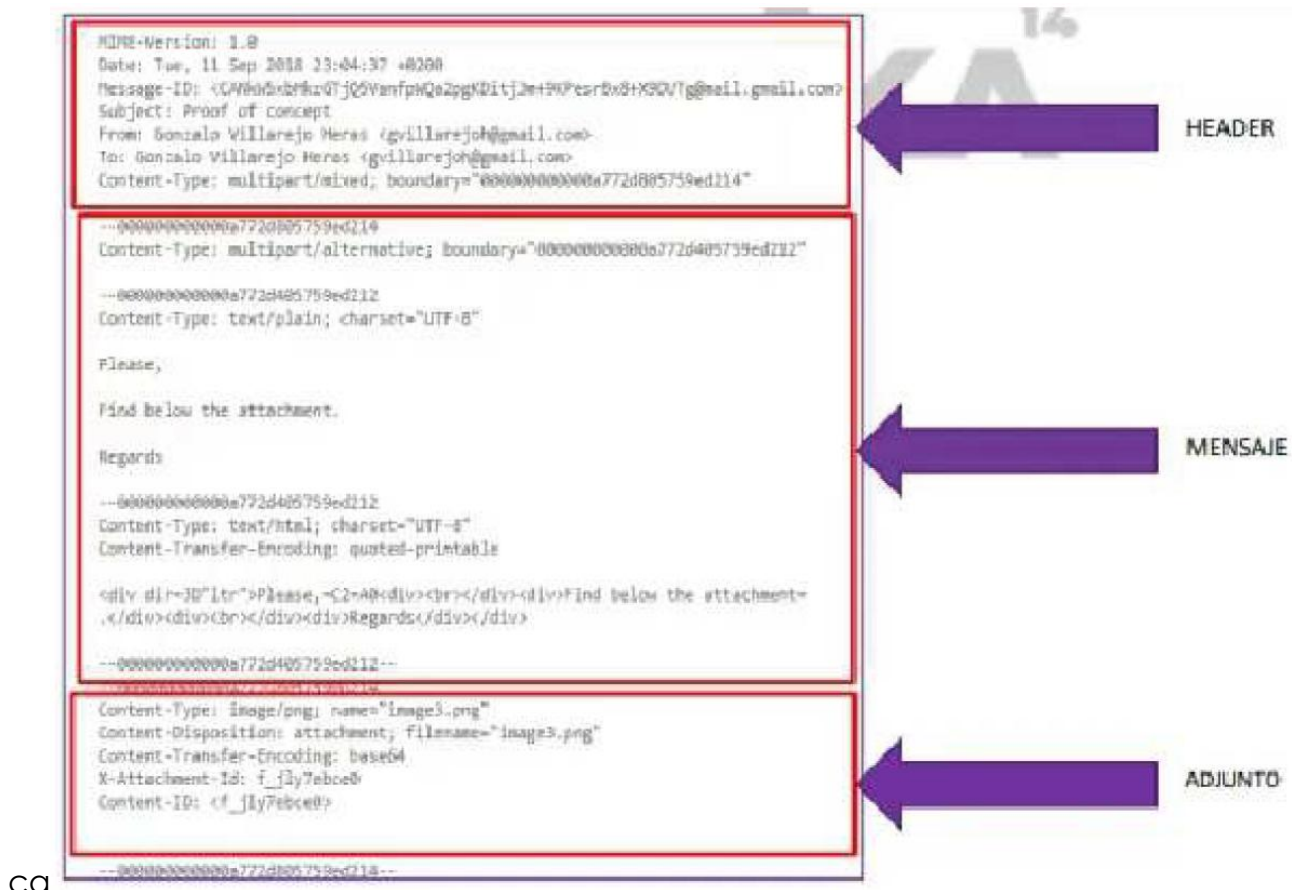
5 Donde hacer el análisis del correo

- Servidor
 - Archivos de buzón (EDB, MBOX, PST, OST)
 - Si se analiza los mensajes de tránsito habría que revisar en los logs
- Cliente
 - Archivos de buzón (MBOX, PST, OST)
 - Archivos de correos individuales (EML, MSG)

6 Partes de un correo electrónico

Las partes que podemos encontrar en un mensaje de correo electrónico:

- **Cabecera:** incluye las opciones de envío, remitente, destinatario/s, dirección de respuesta, asunto y la traza de los servidores por los que pasa, así como un identificador único para ese correo, entre otra información.
- **Cuerpo:** contiene la información enviada en sí misma. Se diferencia por una línea en blanco que lo separa de la cabecera.
- **Adjunto:** contiene archivos que se envían junto con el texto del email.



Otro ejemplo: **Cabecera** **Cuerpo**/**Mensaje** **Adjunto**

Delivered-To: martalagarta70@gmail.com
Received: by 2002:a05:6504:1883:b0:2f1:729:b9fb with SMTP id q3csp2528601l1tt;
Tue, 3 Mar 2026 07:12:25 -0800 (PST)
X-Received: by 2002:a05:600c:5308:b0:483:a352:b4e4 with SMTP id 5b1f17b1804b1-48513a66cf5mr40220015e9.6.1772550744772;
Tue, 03 Mar 2026 07:12:24 -0800 (PST)
ARC-Seal: i=2; a=rsa-sha256; t=1772550744; cv=pass;
d=google.com; s=arc-20240605;
b=i/s3WZtOfR2TReYs1K1SjPg81rW2NVcvQ/UyCgABrukBFLN5rDUwdubC9j134Fo9S
ANAmvy0tW6lBpUVDJWen9AVyJfJD7fsJLMJHSRLX3//sZMw2IOeT2UYFsacxUuU9x7lBfI
PULf1eICUQ4CREt27WEDoOZ2XQT+GxrDqcdvzRfwf7RJV36A0qhyLZ2y9bdULsAj9s3j
P7cneEKr12QQGAbR/OZq2YyIw1kqfg9v4jBCXjX5kV1A2UNgesZwekG3erCSaBHXfCol
LDJUDtMdFrptZ25DKGy75p5tRwMIL5zdmUTZlnQRgZReuZZ+bQK0AUyWUgyE1ERFc7tU
e8AQ==
ARC-Message-Signature: i=2; a=rsa-sha256; c=relaxed/relaxed; d=google.com; s=arc-20240605;
h=mime-version:msip_labels:content-language:accept-language
:message-id:date:thread-index:thread-topic:subject:to:from
:dkim-signature:ironport-hdrordr:ironport-data;
bh=obPlo9LFVxWdUP3xRV80BoHOfQcFWXPu4Ryejw1Hq5c=;
fh=eKV0JD5KL1061ZWtlh4dgsacdSiHvYhaqZsuQ+xFa/Y=;
b=cHsNufR+ahP3ajORRo2QrSjE7wiVXh8sy3doU9S+/bD6EfHBUG/mysR0lrVrxUIr8D
7B6BrRKWYJ2YyEpKmsxm2uyt7YaGE2K4xqz+UgM6ZCqQ8guTjDQq+7G7UfiQgvoqRx
4tU6DhuTeTKRX63qjF494HbmrhMSQMFzUM/g1zoJBg19GajvHnp5Sm16o/iAA/bHntmF
UJ4sNoLKV18E9eIsfCyrHhR19LhLr5fu8xbCkzbWkBBm4bCsu0x7JfWMfcUvd2A7ia68
FktqBRaLtVKAl2+C6iPliCRAgAfK/Fp2ZPoWlByafTImCFEeTtgnRL5qgbtduWsSGOaa
eYHA==;
dara=google.com
ARC-Authentication-Results: i=2; mx.google.com;
dkim=pass header.i=@edu.gva.es header.s=selector1 header.b=RwIGMBdq;
arc=pass (i=1 spf=pass spfdomain=edu.gva.es dkim=pass dkdomain=edu.gva.es dmarc=pass fromdomain=edu.gva.es);
spf=pass (google.com: domain of prvs=515e510d8=pedro.martinez@edu.gva.es designates 193.145.201.30 as permitted
sender) smtp.mailfrom="prvs=515e510d8= pedro.martinez@edu.gva.es";
dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=gva.es
Return-Path: <prvs=515e510d8= pedro.martinez@edu.gva.es>
Received: from mx16.gva.es (mx16a.gva.es. [193.145.201.30])
by mx.google.com with ESMTPS id ffacd0b85a97d-439b732d9f9si12280246f8f.467.2026.03.03.07.12.24
for <martalagarta70@gmail.com>
(version=TLS1_3 cipher=TLS_AES_256_GCM_SHA384 bits=256/256);
Tue, 03 Mar 2026 07:12:24 -0800 (PST)
Received-SPF: pass (google.com: domain of prvs=515e510d8=pedro.martinez@edu.gva.es designates 193.145.201.30 as permitted
sender) client-ip=193.145.201.30;
Authentication-Results: mx.google.com;
dkim=pass header.i=@edu.gva.es header.s=selector1 header.b=RwIGMBdq;
arc=pass (i=1 spf=pass spfdomain=edu.gva.es dkim=pass dkdomain=edu.gva.es dmarc=pass fromdomain=edu.gva.es);
spf=pass (google.com: domain of prvs=515e510d8=pedro.martinez@edu.gva.es designates 193.145.201.30 as permitted
sender) smtp.mailfrom="prvs=515e510d8=pedro.martinez@edu.gva.es";
dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=gva.es
X-CSE-ConnectionGUID: IP/LgB9+Txaprfn1T5vgYA==
X-CSE-MsgGUID: x0c4VhbCRzKTElfDZ64I2g==
X-ThreatScanner-Verdict: Negative
IronPort-Data: A9a23:6992q6I/KVUDDJ/6FE+RVJQ1xSXFzCb7ZxGr2PjLsTEN7I4Qp3ZWk
yFaByqEOJCIfDi1LonCW/2/p04E75XQyYA3QQZk+yg0FCJB9ZKUW4mTcx6sM3ybcZecQRhst
Z5Fz4KzdzFuRy+H+B2mbom4/CMjiPCBT+H1YAKo1kCdYCc9IMt2oU46wrFj6mIRveWEPu+th
T/Ti5SFZAP60W5/a2we566IpuU4f744jpi4wZgP6wX4LXQyyBFXZkSG/q8fiDyKmV28k9WZ
AphIJWRpD6xE8IFU4v9+lrDWhRXBOOUZE7Wlyc+5tGK2nBqvjY13rswKM0SYEJWjyTht91qw
b2hj7TptesSFvOKwrl1vyVwSxkK/UDOOSfeBBTjOTIp6H4Wyyqlx1RJBuFVWEo0r4fKX1D8
/UeNacMYnir78qqwKi2Q/Vbnc8qKs/mJus34hmMGhmAUJ7K6biaK0n7zYcwMAUY36iiLt6HD
yYtUgeDWTybc/F51vX7P7p19AugriGXnzS1Mzt5r4Jvi4TY5FQZPLQArLM50zFFLC1yth/wm
47Iw4j2KjAic/iQ42vGzmKlnvXBm3rHBZwdBZTto5aGgHXLroASiDERZ20B8aKStxbmApRYN
1Ae/Tcooe4q7ku3Q9LhXhq+5nmZohobXNKG0o/gO2P4veOpV/BXy5aEHgYMYxOWMweHFTG0
neLnZxjDDF9ubiIT3WP3rqYsHW9JyFTIHRqiSosEVdcsoGz+dhbYhTnXo5oTJC1hPbPCxLM7
nmEgBpg25RUGptev0m81RWD6962nbdMRxQp7wHeUwu/8gomPKaqYoWp7R7Q6vMoEwqCZlyIv
XxBnc+E80ADEIuKjCGEUuILRejxvazcaW2ahkNzFZ488Tjr42SkYy1b/DB5IgfUL9oAfjjqJ
kTUvGu9+aNuAZdjVocvC6rZNIjg5fKI+QjNPhwMUudzXw==
IronPort-HdrOrd: A9a23:IyWiG6G6HsvI9KIrPqF4JLXdLJyesId70hD6qkvc3Fom52j/f
xGws5x6fatskd2JhSo6H4BEDgEWKUYxCR2+UslNiZLW3bUQeTtb2KjrGSiweIEReOkdK1vJ
0IG8cRNDsAnYkYs+02njcLz9W+qjKzEnHv4fj5kYoaTsvr7Br7g9/BAreOkpgrDNeDZ58OI
uA6tFbZc+Af21SSsigHHEKU8XKutWozfvdEFQ7Li9izDNL0SKj6bb8HRTd9hACUw1XybN3X
nZnx/f/7qCdtej+7hPhZwfc471fhdOk4NpeA86njNQTN1zX+02VtBUkf4fHkCE+oemp51lpvs
LLuQ0cM8N67G6UVn2poDP2sjOQnAoG2jvH8xulKHHjqcv2SHYREMXan79UdRPF9g4JoMx86q
RWxGiU3qAnQio8o3R6NqeQgZSsalnZcckBS0tL7SEYvE7f2XYUh7LD3OnklVavoUhiKrLzPw9
MedP00rMwmCm9yKUqp81WHiebcIOjaEnq9MzI/k93Q3D5MkH9jyUwEgMQZg3cb7Zo4D4JJ/u
LeL81T5cVzp+ItHNBA7d06ML6KI32IRQIJPHOZIFzhGq1CM3XRq4Tv6LFW402xYpQHwJY7hZ
yECTpjxBgPULorDdfl0IXA8xjLTmn4VTPxyttG75w8vrHnXrLkPSCKVVhrmcq9pPcUBNHdRp
+ISeVrKu6mKXGrFzdc3gX4VZUXIX4CUNcNstJ+QF6KqtKjEPyYigUaSoeiGFPAK0dbZozqkOA
p+YNHaHrQ+0mm7HnnlnRPWR3ThPkTi4JMYKtmqw9Qu
X-Talos-CUID: 9a23:DO4fF2P9HvPlau5DeREgOEE+S4MZYNtF1nnWenPlF214YeJa
X-Talos-MUID: =?us-ascii?q?9a23=3AdRRs+g6zFTrCr1t+I5CyJodTxox4u6/yNkAHuq8?=
=?us-ascii?q?UmFPwbCJCcWnBrW64F9o=3D?=
X-IronPort-AV: E=Sophos;i="6.21,322,1763420400";
d="jpg'145?scan'145,208,217,145";a="44190811"
Received: from mail-northeuropeazn11022118.outbound.protection.outlook.com (HELO
DUZPR83CU001.outbound.protection.outlook.com) ([52.101.66.118])
by mx16.gva.es with ESMTP/TLS/TLS_AES_256_GCM_SHA384; 03 Mar 2026 16:12:25 +0100
ARC-Seal: i=1; a=rsa-sha256; s=arcselector10001; d=microsoft.com; cv=none;

b=WkLnx4zby4oip210mWHfY6azUkT/c+ZuYjOeAr0oYYly7zs9yWlOQQeXpae5vhkZm2kWDW9L9kkc3dWWgas1zvZtH+UxvcSVNhtK8kNEvNyUJjFRHEG6nAwX
qB6E5RlDJGDjn6Mb9nSLCZpXRYA5MXnmwnYzyJSG334sqz2jTo0gqmERjmxHq6yTKm57R1qG34V+g4f9s7+au8NRUvKkoNF0EixGcQrdJepw2yvyTd+0A0sughxA
YyJW04bL3kbbvXIf0zCfnVm/G2RAPIUQpakun2IsplrXykwIvIjxqpbXS6ztR7CB7hlo40mq64WR5rrw1tv6qqIhxmFZDH3w==
ARC-Message-Signature: i=1; a=rsa-sha256; c=relaxed/relaxed; d=microsoft.com;
s=arcselector10001;
h=From:Subject:Message-ID:Content-Type:MIME-Version:X-MS-Exchange-AntiSpam-MessageData-ChunkCount:X-MS-Exchange-
AntiSpam-MessageData-0:X-MS-Exchange-AntiSpam-MessageData-1;

bh=obPLo9LFVxWdUP3xRV80BoHOfQcFWXPu4Ryejw1Hq5c=;

b=IZPPCWGM9sRpugP6wvclKIwKyw5A6q6obUWam/HiT3vz0DGKce9uKyJzfzJnMZJXWB5NDRT9ayqbs7dzfGEQrQ80bTQGHCsQFR7Kkowi752W3seNmneQB1Eul5fk+C4ky2Udwv1gGULRkOs03TNOQzSzPch78cBurNB1GPhf3Vgo/MQEY32MoHGunvagD0ih4BWS5MBFohW6tZ7FS0QH1qDxHETEn0ubpdZfkVji8RgD7eGhaQZjdvM93CqHT7djUOaxi86j1fTO/+sn0fa3hdRpZcf6aQ3j4g9XwI9ghtkBrRwB3IilpwpFSdPCsZVcWweHfgKct4/XrCx/Fe16Q==

ARC-Authentication-Results: i=1; mx.microsoft.com 1; spf=pass
smtp.mailfrom=edu.gva.es; dmarc=pass action=none header.from=edu.gva.es;
dkim=pass header.d=edu.gva.es; arc=none

DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=edu.gva.es;
s=selector1;
h=From:Date:Subject:Message-ID:Content-Type:MIME-Version:X-MS-Exchange-SenderADCheck;
bh=obPLo9LFVxWdUP3xRV80BoHOfQcFWXPu4Ryejw1Hq5c=;

b=RwIgMBdqlGzEzlpcts2DgEz6J3vJ4skKQcjALEbz2mbA5Z+jWANVxKfIrg48/ymp9wN/2qcLLHUz1OfhE2hOObKhFDUeq9wExapc9UAYH2ykQyFLhagvZu+7COoMgoB20koA8s/xKtEODYrZ12LDwphp36SxX2KI+nC3x9YEeNOvaTB26TXDO11b0615JEI0zEA8k3pcRjMNP4cRp4Ie6fVJ04f1uvui8R+QIC/T25bJsazmo9wpug3ZvsvPagZ4NyBMXafzEDgjkdhIq1jMEI5hesdL+6F3PcnfGdr3xXUvfJv4yHkT01H72PNEP3tJkdhSdZKNE3UL2dxeC0AR8Q==

Received: from GV1P194MB1859.EURP194.PROD.OUTLOOK.COM (2603:10a6:150:57::8) by AS8P194MB1382.EURP194.PROD.OUTLOOK.COM (2603:10a6:20b:3c3::22) with Microsoft SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.9632.13; Tue, 3 Mar 2026 15:12:22 +0000

Received: from GV1P194MB1859.EURP194.PROD.OUTLOOK.COM ([fe80::5fb3:2d43:5558:a5e3]) by GV1P194MB1859.EURP194.PROD.OUTLOOK.COM ([fe80::5fb3:2d43:5558:a5e3%5]) with mapi id 15.20.9678.016; Tue, 3 Mar 2026 15:12:21 +0000

From: =?iso-8859-1?Q?MARTINEZ=2C_PEDRO?= <pedro.martinez@edu.gva.es>
To: "martalagarta70@gmail.com" <martalagarta70@gmail.com>
Subject: MOVIL
Thread-Topic: MOVIL
Thread-Index: AQHcgyAThnjLp7yHAKhe00yQiNynA==
Date: Tue, 3 Mar 2026 15:12:21 +0000

Message-ID: <GV1P194MB1859E8DCE78C333649345990D87FA@GV1P194MB1859.EURP194.PROD.OUTLOOK.COM>

Accept-Language: es-ES, en-GB, en-US
Content-Language: es-ES
X-MS-Has-Attach: yes
X-MS-TNEF-Correlator: msip_labels: authentication-results: dkim=none (message not signed) header.d=none;dmarc=none action=none header.from=edu.gva.es; x-ms-publictraffictype: Email x-ms-traffictypediagnostic: GV1P194MB1859:EE_|AS8P194MB1382:EE x-ms-office365-filtering-correlation-id: e60889a6-cb92-4df6-1296-08de793744ab x-ms-exchange-senderadcheck: 1 x-ms-exchange-antispam-relay: 0 x-microsoft-antispam: BCL:0;ARA:13230040|1800799024|786006|366016|376014|6049299003|4053099003|8096899003|38070700021; x-microsoft-antispam-message-info:

eMsI0kp/n3RjEiWQG49jMNaaxaFfQJVcmVasltav0fHnFOWglUVuvzrPPiKwJvhMV0kkR++cVizqswsefoztjiSiMiIg+1qssc8U4086fIX3itpsOmfvGS3SsHJ9g0hX0u/pCGJT0yYbRlue/UXQulnMia/wYlvxTH7rePL+7QXY1zqvlujRdpRmmr9151Hf19BLGGoPatX9JAT6/rBoNx5Ti2oZp6t/bk9pyZzSD1R76tgAXe1IZroyxpYSE9C04Ym6VqwfVfuto9R5Rc+gbbOqii5ACrNdE8Lbo4o8T1hP4vXxe3YMoQfWlabSXXRzrCRJ0BX74Um3ZIZdOZ8TgUR0uKXeDGx0QCL/3FjvB7etpZqqcXGt xXJr5EGM+mjtD5TmZFsx6wKq2KpFLWP4Uha0+vesYc6GSsKNzLK9IxzQnia2vwd/+RExLbo6ULM69Q24FKWcBnFUyCaw/A4ixTcWmu5aOiOD1WPtpJAfW0FShW+ xkFqh5dnFUPU1BhplrOHpyBqfEF8GtYkfmd01Jpz7L3AexY70ShoqD0cQgiccs4gKJZRaMN4CxdEH7f9QjCwtmq8JtHj7DHml3DY0qbW5cdcC76jyvOoghTz24vRH1rMwd+XN9aqfLbLoSy5QBwUfqud9RyA/O+pTMHggvk7Izsouw6Rh7NWD0RFVno8wlYxt9HytcB35oHylLiLnZ3ddc2imH7FyFwHgdK4dybql2Jxu61Yh5QI3ifVRUXNLVB7/rCbazEgUaq9nl+/7UkZ6rJ+2BtrKr+6Lsulg== x-forefront-antispam-report:

CIP:255.255.255.255;CTRY:;LANG:es;SCL:1;SRV:;IPV:NLI;SFV:NSPM;H:GV1P194MB1859.EURP194.PROD.OUTLOOK.COM;PTR:;CAT:NONE;SFS:(13230040)(1800799024)(786006)(366016)(376014)(6049299003)(4053099003)(8096899003)(38070700021);DIR:OUT;SFP:1102;
x-ms-exchange-antispam-messagedata-chunkcount: 1
x-ms-exchange-antispam-messagedata-0: =?iso-8859-1?Q?FriOScnCUJUWprbgvib7/9W0gxpB1P1KiLsneYURQEGHGjcdFDK+Qm3ChR?=?iso-8859-1?Q?D2qQUfU8MVwdxrFNbsGCKha6et8JedAglYyJn3l/WBKrMr0QQZ7ngW+5M0?=?iso-8859-1?Q?byJqmWicyhmbBhDA17qveFNPYVxSOKHKOHNSAQjgIrl6VTlznxxRmq6fRZ?=?iso-8859-1?Q?TMNlkBv7w0nyKd6IPhxebByco4ZipYMS8ags39RaT7XgK/VdMTm2iiYmVv?=?iso-8859-1?Q?5rw2rhpPR+gVWdthQls7wz9FLDjNlWOM10D0szAjuRxPZGrthqlS2yk54y?=?iso-8859-1?Q?kN2sK7y9nVu5hREObuClz/6MzXsBMZK+ybuPvtsVnWSrxnKFXixL8+m2x5?=?iso-8859-1?Q?2dXhdhyysa+92JxIwmCzozj4fcPKfJDqhNJLeMYvXTGNWTrq5Sly87v1n20?=?iso-8859-1?Q?rhTs4H38YbpXmsTA8euwHN3ZqHBA3jt+wVbNKp0kcyqXINlaIQSG1FJaI9?=?iso-8859-1?Q?TAFqU6MCC0u+IYbt7T8ur/01CHLxiCiqWxMRWQAa5GnoNFqnnAVk7drhQ?=?iso-8859-1?Q?spZO1L1BNeCL0cOM6TtZvh5mdyRKMzM19v7U607YDZiY8gK20NePJWZfNR?=?iso-8859-1?Q?eAJYvTRcjOabZ3mBSUW1TIqO8/DOz3lNomzO1F24/SQJew872IKZsW5HVN?=?iso-8859-1?Q?roLIGSDebaxjki9wH8O3Y+8vN1Tna34ajExNFTZ4B7tNZAenpfK5oB8L39?=?iso-8859-1?Q?RPvzs+X4B3LXXK3ssEk8aEoTJeKqxUHFoHROV3r4mS8DXnIeon6eXk2N7aY?=?iso-8859-1?Q?IIQaBXcVhr2M4CLgAmnwOzfmDOXlU6aqKgRs4mtaIeF4G9IAAm5MhNdLN3?=?iso-8859-1?Q?/cblN8Wrt0Xxnm05ZSLbiF1XrA/runBIkvqP8I/qz7UhlfnZkL3NWZLfIt?=?iso-8859-1?Q?1+moJh0QNR0qp+3RYzRHX7WxvapfwYJEQLLWxXowlFOpTnayJYO/IxXXGS?=?iso-8859-1?Q?K6XZqWAGskNtXJ03v/ODD+jZIFGSwl0xWZU+y1/MHfT80SbzxHxsuftVP50?=?iso-8859-1?Q?di3Kl5CE6M7VXspdB7KGsCTqI/OfpcD+5tWhcFDcvIN23VjyODdil700n0?=?iso-8859-1?Q?1NdcfRBL90+HGU5LH4LgU+/5hliZx6DUqA4HWiMfIdpFYlt0Avp8s5t4ss?=?iso-8859-1?Q?y7BCgwaSc6GLSk1S5nRgB042onTF7LqIWqouxwCLrzc5DOq+M4KQbcSPk?=?iso-8859-1?Q?RSVaQkoPxo2uknV10dESlFwL06p8euTWmtAGjdplDlI6rg/dR9MXDNz/3m?=?iso-8859-1?Q?Wa16FVouGk+0/gW8EQ24W1xiW86hlw+eBWDYSB/0cCy3/22KTeBZ5y3LF/?=?iso-8859-1?Q?nrQHPtQM04hYnNoKcVpaoyupPmA5i7p5rSrysD3rC6LqvPXsOmTp9CjAoc?=?iso-8859-1?Q?mn7SxFS52WqD8HC/ak+KHJdE6GXXKZPQOoesLpRV6Mq+MpvR/1rRj5rjClx?=?iso-8859-1?Q?sDaLnmvJuzquWSFM9E+1A+gRUG4lSBVnQEwtJt9gFL6ZDeYt1dLkWG8sJM?=?iso-8859-1?Q?tOFAYTAcs+XsEdiRsdmwjct+T4WqCIfyI8evzQCfZA8LM3MGcKox8TgtXy?=?iso-8859-1?Q?HVI9FAE7eeeHYlYtezV/zUGk7abAIdwU56oqCaLzTdGCPP1XizLnPfjEO?=?iso-8859-1?Q?W/Anvj3kpwllkgye/xZArpNyP8rjFHyZ7FqpyCj60F2omV2nfCdhlvkgqsQM?=?iso-8859-1?Q?2HNH0hTMU4DKLbn8WaT+qYold4tvrgZ69cSHsffgKwy8JyzIvMv8eqfi4W?=?iso-8859-1?Q?2hvw1H109xv7FbCSm8/QCoLoJAsENR1/ofM8RqSc8sGRfJTYBaiVbsFQFrw?=?iso-8859-1?Q?IeuNCir5XQ?3D=3D?=? Content-Type: multipart/mixed; boundary="_004_GV1P194MB1859E8DCE78C333649345990D87FAGV1P194MB1859EURP_" MIME-Version: 1.0 X-MS-Exchange-AntiSpam-ExternalHop-MessageData-ChunkCount: 1 X-MS-Exchange-AntiSpam-ExternalHop-MessageData-0:

7.1 Campo RECEIVED

Uno de los principales campos a analizar es el denominado **Received**. Esta cabecera va a indicar todos los servidores por los que ha pasado el mensaje hasta llegar al buzón del usuario final.

Al contrario que el resto de la cabecera, esta **es la única que no puede ser modificada por un atacante**, por lo cual va a proporcionar datos verídicos y fiables para el análisis.

Una peculiaridad de la cabecera es que hay que leerla de abajo hacia arriba. Es decir, el correo va a pasar por una serie de servidores, así que por cada uno de ellos va a aparecer una cabecera **Received**. Para ubicar el servidor origen, que es que el interesa, será el que identifique el último

[illegible]

7.2 Campo MESSAGE ID

Lo proporciona el servidor que envía el email y consiste en un único identificador añadido al nombre del servidor con la @.

Este campo puede ser utilizado para identificar mensajes relacionados gracias al tag **References** y **InReply-To**:

```

MIME-Version: 1.0
Date: Mon, 3 May 2021 12:18:51 +0200
References: <CAGF15Fj2Fic3w4UNhxy3teUv_wF3SU8mqrtlgck-8torfg@mail.gmail.com> <CAHPuR35sxBCTPp6U6CVSyoufDc=1=8ylyY=Zrmr=D+ksD24@mail.gmail.com>
In-Reply-To: <CAHPuR35sxBCTPp6U6CVSyoufDc=1=8ylyY=Zrmr=D+ksD24@mail.gmail.com>
Message-ID: <CAGF15Fj2h84/f4X0j0n513602dk-9sZi6-q8SUQ7pu4=-x0@mail.gmail.com>
Subject: Re: CV David Sánchez
From: "Sánchez Rubio, Mari Luz" <mlsanchez@iestrassierro.com>
MIME-Version: 1.0
Content-Type: text/html; charset=UTF-8
Content-Transfer-Encoding: quoted-printable

```

Mensajes	Message-ID
Mensaje origen	CAGF1SEJ2Fic9w4LNMhku3HeoV_wvF35U6mqrtzLgck-6-Lozfg@gmail.com
Responder al mensaje anterior	CAHPPUoR3SmxBC7P0p6UGCBSynouRdp=1H0yLyY=Zrnr+d+WsD2A@mail.gmail.com
Responder al mensaje anterior	CAGF15Ejc2b8Rdf4XC0jOnSi3GO2k-9sZiG-q8SUJQ7pu4-cxQ@mail.gmail.com

En la conversación anterior, se puede ver el histórico de **Message ID** que hay, Esto indica que hay 3 mensajes, uno por cada **Message ID**.

Otro ejemplo de reenvío de un mensaje original de una cuenta de Outlook, reenviado desde una cuenta de Gmail:

```
Mime-Version: 1.0
References: <GV1P194MB1859E8DCE78C333649345990D87FA@GV1P194MB1859.EURP194.PROD.OUTLOOK.COM>
In-Reply-To: <GV1P194MB1859E8DCE78C333649345990D87FA@GV1P194MB1859.EURP194.PROD.OUTLOOK.COM>
From: Marta Lagarta <martalagarta70@gmail.com>
Date: Tue, 03 Mar 2026 17:55:54 +0100
X-Gm-Features: AaiRm53JeptUYfh21bNWU-OBpJi-yDrrIWzXCC83gEXrW75Vbfnf1eMNq48Xk-Y
Message-Id: <CACBXYk7ExnMarJue+6hbQhq=5JZmiy4ySu73cS6VceswMGTXEw@mail.gmail.com>
```

7.3 Campo MAPI HEADERS

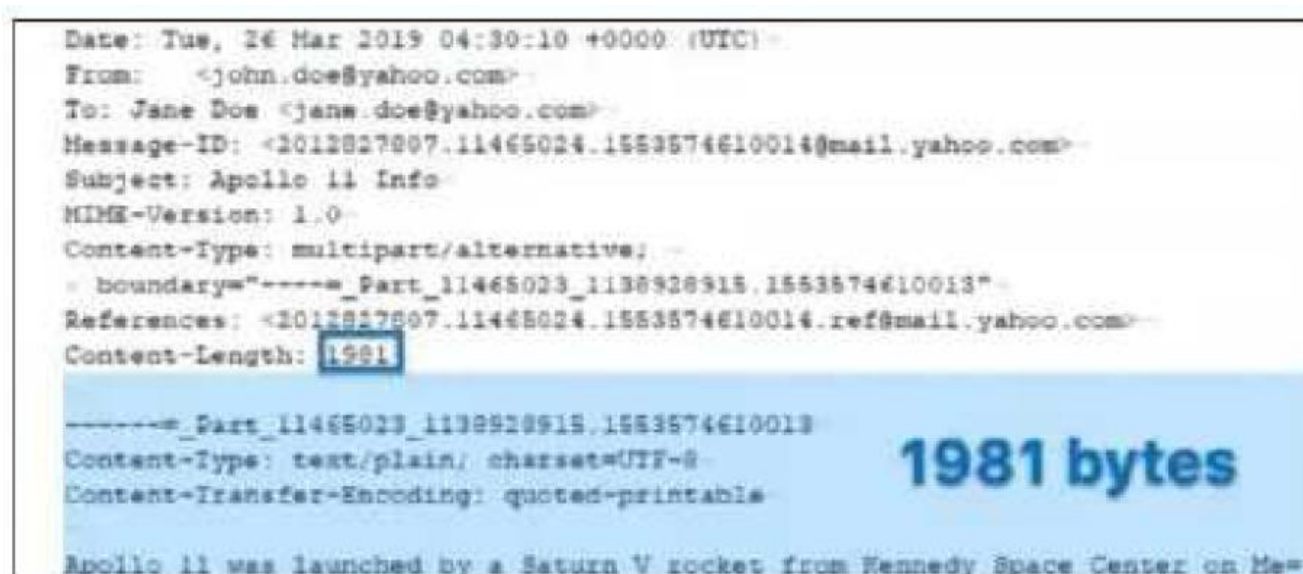
Si se está realizando una investigación donde hay un servidor Exchange o clientes tales como Microsoft Outlook, hay que ser consciente que las propiedades MAPI (Microsoft Messaging Application Programming Interface) estarán presentes. Son unas cabeceras adicionales que van a permitir extraer más información de un simple correo electrónico.

- **Mapi-Client-Submit-Time:** La fecha del sistema local cuando el email fue enviado por el cliente.
- **Mapi-Conversation-Index:** Indica cuantos mensajes hijos fueron parte de la cadena de emails y registra los timestamps para cada mensaje de cadena.
- **Mapi-Entry-ID:** Un identificador de mensaje dentro del almacenamiento como PST. Puede ayudar a identificar si un usuario disponía de varios ficheros PSTs.

- **Mapi-Message-Flags** y **Pr_last_Verb_Executed**: Proporciona información detallada de las acciones que ocurrieron en un cliente MAPI: Leído, sin leer, respondidos, reenviados, fuera de la oficina.

7.4 Campo CONTENT LENGTH

Este campo es utilizado para verificar el payload del correo. Es decir, si se está investigando una posible modificación del correo electrónico, se podría volver a calcular el tamaño para ver si de verdad tiene el tamaño que indica. No es utilizado por dos los sistemas de correo.



7.5 Protocolos de Autenticación

SPF/DKIM/DMARC es un triple sistema de autenticación de correo electrónico que verifica la legitimidad del remitente: SPF valida la IP autorizada, DKIM aplica firma criptográfica al mensaje, y DMARC establece la política de rechazo para emails no verificados.

Los registros o protocolos de autenticación SPF, DKIM y DMARC nos pueden ayudar a evitar que se manden correos suplantando nuestra identidad. También sirven para dar más seguridad a los servidores de destino de nuestros correos y así evitar, dentro de lo posible, que sean marcados como SPAM.

Cada uno de estos protocolos tienen un papel diferente en la seguridad de los envíos de correo, combinan herramientas estandarizadas de autenticación y cifrado (firmas públicas y privadas; registros DNS, etc.) para verificar la identidad de remitentes de correo electrónico.

7.5.1 Situación actual

El 82% de las empresas españolas (o sus servicios) NO tienen configurado DMARC con política de rechazo ($p=reject$), dejando sus dominios vulnerables a suplantación de identidad vía email. En 2025, una campaña [phishing](#) suplantó a la AEAT enviando 420,000 emails fraudulentos desde servidores no autorizados. Si la AEAT hubiera tenido DMARC $p=reject$ configurado, los proveedores email (Gmail, Outlook) habrían rechazado automáticamente esos mensajes antes de llegar a las víctimas. Coste del fraude: €8.3M robados.

Adopción en España al inicio del 2026:

- Solo 18% dominios mundiales tienen DMARC publicado
- Solo 4% tienen DMARC $p=reject$ (protección máxima)
- 41% bancos NO tienen DMARC (vulnerables phishing)
- Coste medio breach phishing: €4.88M por incidente

Nota: Si la cabecera del mensaje tuviera el resultado del DMARC, no sería necesario analizar el resultado de cada protocolo de autenticación.

7.5.2 DKIM (DomainKeys Identified Mail)

Es una técnica de autenticación de correo electrónico que permite al receptor ver que un correo electrónico fue sin duda, enviado y autorizado por el dueño de ese dominio. Esto es el hecho al darle al correo electrónico una firma digital. La firma DKIM es un encabezado que se añade al mensaje y está asegurado con encriptación.

```
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/simple; d=iestrassierra.ga; s=dkimIDmail; t=1619031311; bh=ap+Rms8NOPpeQYnaYCRjj/SX1PbCCsCfLFciyiUj04s=; h=Date:Subject:To:From:From;
b=c3IgwJ2h38eTPq1tBmtJQEWPxeJ03vcHqAIsG+6BNzOHMGDzHktaknkf8aQ53W0Jy
f4T8Pv+d09JtmX66w6+2Qb5hpGQ0lpHgKNqvc5AhMF4A8n5L5rsDEzVsBb06pyNnrG
4b+n09vbocmoR0wdAC41hioCHgpGNBsB4RcB2J/eRLgiwQI3I1fmfBcmjGyM7qjhpL
tZAefbmJ30G7VBYXAMXCS8ehByXlRnpg/vW3+v99L1IBFcFIBqOvt12ZBZBwUjtFTY
FO7Dj1TnzzgJBhVURvWLUQ+Diq1gqAaE1w2cI2pBXtLIO/q9vTgYpSWDm8m8rbZxmU
oig5H2mHuMuTg==

MIME-Version: 1.0
Date: Wed, 21 Apr 2021 10:55:11 +0000
X-Mailer: Microsoft Office Outlook, build 17.55210
Message-ID: <1619031311920593720.1782.113810739735829770@iestrassierra.ga>
X-Message-Occulted: Si ves este mensaje, soy Sergio Rojas :3
X-Message-Occulted2: Recuerdos del grupo de Especialización en Ciberseguridad en Entornos de las Tecnologías de la Información :3
Subject: Corrección de datos en moodle
To: "Sánchez Rubio
Mari Luz" <mlsanchez@iestrassierra.com>
From: Equipo moodle TIC <moodle10@iestrassierra.ga>
Content-Type: text/html; charset=UTF-8
Content-Transfer-Encoding: quoted-printable
```

```
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/simple;
d=iestrassierra.ga; s=dkimIDmail; t=1619031311;
bh=ap+Rms8NOPpeQYnaYCRjj/SX1PbCCsCfLFciyiUj04s=;
h=Date:Subject:To:From:From;
b=c3IgwJ2h38eTPq1tBmtJQEWPxeJ03vcHqAIsG+6BNzOHMGDzHktaknkf8aQ53W0Jy
f4T8Pv+d09JtmX66w6+2Qb5hpGQ0lpHgKNqvc5AhMF4A8n5L5rsDEzVsBb06pyNnrG
4b+n09vbocmoR0wdAC41hioCHgpGNBsB4RcB2J/eRLgiwQI3I1fmfBcmjGyM7qjhpL
tZAefbmJ30G7VBYXAMXCS8ehByXlRnpg/vW3+v99L1IBFcFIBqOvt12ZBZBwUjtFTY
FO7Dj1TnzzgJBhVURvWLUQ+Diq1gqAaE1w2cI2pBXtLIO/q9vTgYpSWDm8m8rbZxmU
oig5H2mHuMuTg==
```


- **v**= indica la versión de la especificación DKIM
- **a**= especifica el algoritmo que fue utilizado para crear la firma.
- **c**= indica como el body y headers del email fueron preparados para hashear. relaxed/relaxed, significa que aplicó a ambos. c=relaxed, solo al header y c=simple, solo al body
- **d**= indica el dominio al cual se debe reclamar la responsabilidad de transmisión del mensaje
- **s**=indica el selector para el dominio.
- **bh**=indica el hash del body del mensaje en base64.
- **h**=indican los campos que fueron incluidos en la firma.
- **b**=datos de la firma en base 64.

Por ejemplo, podemos utilizar el comando **dig** para averiguar información del protocolo de autenticación del DKIM de edu.gva.es:

```
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=edu.gva.es;
s=selector1;
h=From:Date:Subject:Message-ID:Content-Type:MIME-Version:X-MS-Exchange-SenderADCheck;
bh=obPLo9LFVxWdUP3xRV80B0h0FQcFwXPu4Ryejw1Hq5c=;
b=RwIgMBdq1GzEz1pcts2DgEz6J3vJ4skKQcJALBz2mbA5Z+jWANVxKfQIrg48/ypm9wN/2qcLLHUz10fhE2h00BKHFUeq9wExapc9UAYH2ykQyFLhagvZu+
7C0oMgoB20koA8s/xKtEODyrZ12LDwphp36SzX2KI+nC3x9YEeNOvaTB26TXDOI1b0615JEI0zEA8k3pcRjNP4cRp4Ie6VJ04f1uvui8R+QIC/T25bJsazmo9w
pug3ZvsvPAgZ4NyBMXafzEDgjkdhIQ1jMEI5hesdL+6F3PcNfgDr3xXUvfJv4yHkT01H72PNEP3tJkdhSdZKNE3UL2dxeC0AR8Q==
```

```
(kali@kali)-[~]
$ dig TXT selector1._domainkey.edu.gva.es

; <>> DiG 9.20.18-1-Debian <>> TXT selector1._domainkey.edu.gva.es
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 20462
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1220
; COOKIE: dd8427ab26a74bcd1facd4cf69a716b347fda04c19db47a4 (good)
;; QUESTION SECTION:
;selector1._domainkey.edu.gva.es. IN      TXT

;; ANSWER SECTION:
selector1._domainkey.edu.gva.es. 300 IN CNAME  selector1-edu-gva-es._domainkey.gvaedu.n-v1.dkim.mail.microsoft.
selector1-edu-gva-es._domainkey.gvaedu.n-v1.dkim.mail.microsoft. 3600 IN TXT "v=DKIM1; k=rsa; p=MIIBIjANBgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEA
7dwwb0bZVd94Qqa8dnBxyIYlldzQHR/j+Uah5CqONsKvafksYvry/xIWF8cVmmpgIjntY540jAE/xJl4tjNsoQmDNCtLLT2z2FLk1H0S9XZ2Fp1e3NOAf8tfVraprZSRU8sjJ0faRNwV
bpbFCguJT2fTU7Jw35z3y5+YgHayibxmsw0Kd5+TffYtiYzz4aut8" "xc784WxChsdm+kLa2UtymUJ0S1SFVRfcT6BmcGxTSut46ZMD0c9Ug686A1v0ayfTeyFx2m11GkzPKlQJXk4v
Kj5c4xsQQtvBaWmao9YiRMTb9MexZyjf33KjZ3K1jde0LVTBUB05GPs0xaQq8Yt0QIDAQAB;"

;; Query time: 231 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Mar 03 12:13:22 EST 2026
;; MSG SIZE rcvd: 590
```

En la captura observamos en el campo p la clave pública que podríamos utilizar para contrastar los datos de la firma en base 64 (campo b de la firma DKIM). Pero esa es la tarea del DKIM y el resultado se observa en el campo **Authentication-Results**:

```
Authentication-Results: mx.google.com;
dkim=pass header.i=@edu.gva.es header.s=selector1 header.b=RwIgMBdq;
arc=pass (i=1 spf=pass spfdomain=edu.gva.es dkim=pass dkdomain=edu.gva.es dmarc=pass fromdomain=edu.gva.es);
spf=pass (google.com: domain of prvs=515e510d8=pedro.martinez@edu.gva.es designates 193.145.201.30 as permitted sender)
smtp.mailfrom="prvs=515e510d8=pedro.martinez@edu.gva.es";
dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=gva.es
```

También podríamos haber consultado el registro con el comando de PowerShell:

```
Resolve-DnsName -Name selector1._domainkey.edu.gva.es -Type TXT
```

7.5.3 SPF

Sender Policy Framework (SPF) es un protocolo de seguridad de correo electrónico que se utiliza para verificar el remitente. El sistema reenvía el mensaje solo después de autenticar la identidad del remitente. La técnica utiliza la dirección de dominio para la autenticación y agrega el estado de verificación en el campo de encabezado.

```
Received: from iestrassierra.ga (254.red-81-43-38.staticip.rima-tde.net. [81.43.38.254])
  by mx.google.com with UTF8SMTPS id a25s1334126wmm.12.2021.04.21.11.55.12
  for <mlsanchez@iestrassierra.com>
  (version=TLS1_3 cipher=TLS_AES_256_GCM_SHA384 bits=256/256);
Wed, 21 Apr 2021 11:55:12 -0700 (PDT)
Received-SPF: pass (google.com: domain of moodletic@iestrassierra.ga designates 81.43.38.254 as permitted sender) client-ip=81.43.38.254;
Authentication-Results: mx.google.com;
  dkim-pass header.i@iestrassierra.ga header.s-dkimIDmail header.b-c3IgwJ2h;
```

En la cabecera anterior, se indica el resultado SPF determinado por el servidor destinatario. Los posibles valores son los siguientes:

- **Pass:** se ha verificado en el DNS que la IP consultada está autorizada para enviar correos electrónicos en nombre del dominio.
- **SoftFail/Fail:** se ha verificado en el DNS que la IP consultada no está autorizada para enviar correos electrónicos en nombre del dominio.
- **Neutral:** no se ha podido verificar en el DNS que la IP consultada esté autorizada para enviar correos electrónicos en nombre del dominio. Puede deberse a que no se haya configurado ningún registro SPF o DNS no esté autorizado para indicar dicha información.
- **None:** Este valor indica que no se ha configurado ningún registro SPF en el servidor DNS. Se comporta igual que Neutral.

También podemos usar el comando **dig** para revisar el SPF de edu.gva.es. Partimos del SPF de edu.gva.es:

```
Received-SPF: pass (google.com: domain of prvs=515e510d8=pedro.martinez@edu.gva.es designates 193.145.201.30 as permitted sender)
client-ip=193.145.201.30;
```

```
(kali@kali)-[~]
└─$ dig TXT edu.gva.es

;<>> DiG 9.20.18-1-Debian <>> TXT edu.gva.es
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 24497
;; flags: qr rd ra; QUERY: 1, ANSWER: 3, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1220
; COOKIE: a75a76f00bc11f986470afd269a71f09becf2f2c6b479dfb (good)
;; QUESTION SECTION:
;edu.gva.es.                IN      TXT

;; ANSWER SECTION:
edu.gva.es.                5      IN      TXT      "sophos-domain-verification=8c3e0b78960d9d2b53c960a1d7d2d32d2999f5adae0c494bf9bd8259c1f0e283"
edu.gva.es.                5      IN      TXT      "v=spf1 include:gva.es -all"
edu.gva.es.                5      IN      TXT      "apple-domain-verification=zM8BV0zDXIzOhibG"

;; Query time: 40 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Mar 03 12:48:55 EST 2026
;; MSG SIZE rcvd: 265
```

No encontramos mucho, pero si vemos que el registro spf está en gva.es. Hacemos otra consulta:

```
(kali@kali)-[~]
$ dig gva.es TXT +short
"qZ10YhnYau0KY+/uV7nsPlJen1DnzU8nOkP+mHdhUJ2cn1A4dhWdvv4WUJ7VkB1ERKfVM9ARKVzN2821acHC60kw=="
"v=spf1 include:spf.protection.outlook.com include:mta.gva.es include:mtallistes.gva.es include:spf.difusio.gva.es" "-all"
"mdt-site-verification=7b8/r40a0635624eTDT3d5UC983TCLa3Ca3015/083aa02000T219000C90a0C83"
"msfpkey=5r4plvmmdm7fz7mp4vzcvox9r"
"atlassian-domain-verification=6vUJYiAaSVQsYJUQ5whvLCVMYaVRHFzN1AfprWEHy0B9olsSm4kGLQMvzbw7IaWJ"
"duo_sso_verification=HGLUIFPtBNuzIvgbmGQhMqR1TadAZg9AZK5YrDdEfSpGP1eJC4e8Tf0rWtrRzeBq"
"google-site-verification=S4KCqEwh2unPEAu7QMAwwLgsgV3B2PLW5R_MEM1CBm4"
"MS=ms78497255"
"google-site-verification=9hqV-_DNEiHYtc8lfYL7yhN8_vklwWqN4qx_Q5Vy6Aw"
"zz8vkg9krghwb0y80vsy7gym0scb1ss"
"4T6-3F2-6N3"
"spf2.0/pra include:mta.gva.es a:dunas.gva.es a:sarabi.gva.es" "-all"
"ob4sc1q3kjtdu8i5n6fapkn6f"
"_w825sw632cd12azm62h0nsbwj0wlu"
"MS=D794038059E1E34740468FA9F6CF13D17CFC628E"
"MS=ms77761276"
```

Y ahora si encontramos el registro spf, está en spf.protection.outlook.com. Lo consultamos:

```
(kali@kali)-[~]
$ dig TXT spf.protection.outlook.com +short
"v=spf1 ip4:40.92.0.0/15 ip4:40.107.0.0/16 ip4:52.100.0.0/15 ip4:52.102.0.0/16 ip4:52.103.0.0/17 ip4:104.47.0.0/17 ip6:2a01:111:f400::/48 ip6:2a01:111:f403::/49 ip6:2a01:111:f403:8000::/51 ip6:2a01:111:f403:c000::/51 ip6:2a01:111:f403:f000::/52 -all"
```

Y ahora si vemos los rangos de IP's autorizados para ser remitentes del correo.

Una vez más, clarificar que todo esto no es necesario que lo hagamos, podemos fiarnos del pass incluido en el Received-SPF. Pero si tenemos sospechas o necesitamos hacer un informe forense exhaustivo, si deberíamos hacer y evidenciar estas comprobaciones.

7.5.4 DMARC

DMARC (Domain-based Message Authentication, Reporting and Conformance, Autenticación de Mensajes Basada en Dominios, Informes y Conformidad), es un mecanismo de autenticación de correo electrónico. Ha sido diseñado para otorgar a los propietarios de dominios de correo electrónico la capacidad de proteger su dominio frente a su uso no autorizado, comúnmente conocido como email spoofing.

La protección DMARC se encarga de indicar al servidor destinatario qué hacer con el correo si las valoraciones dadas por SPF y DKIM han determinado que el mensaje es una suplantación de identidad.

Por tanto, **para que un mensaje sea validado por DMARC, debe pasar la autenticación SPF y/o la autenticación DKIM.** En cambio, **si fallan, el mensaje será rechazado.**

```
-----
dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=iestrassierra.ga
```

El parámetro clave es p. Este define cómo se quiere que el servidor receptor gestione los mensajes sospechosos que le llegan haciéndose pasar por tu dominio. Este campo puede estar compuesto por uno de los siguientes valores.

- **None:** indica al servidor que no haga nada con el mensaje y siga sus propias políticas para determinar el destino del mismo. Este es el valor por defecto.

- **Quarantine:** indica al servidor que marque los mensajes como spam y que los mantenga en cuarentena a la espera de seguir tratándolos. También se enviaría notificación a la entidad suplantada.
- **Reject:** indica al servidor que rechace el correo, evitando que llegue al destinatario. Al igual que los anteriores se enviaría notificación a la entidad suplantada.

Una vez más podemos comprobar la configuración del DMARC de edu.gva.es. Observemos primero el trozo de la cabecera asociado al DMARC:

```
Authentication-Results: mx.google.com;
  dkim=pass header.i=@edu.gva.es header.s=selector1 header.b=RwIgMBdq;
  arc=pass (i=1 spf=pass spfdomain=edu.gva.es dkim=pass dkdomain=edu.gva.es dmarc=pass fromdomain=edu.gva.es);
  spf=pass (google.com: domain of prvs=515e510d8=pedro.martinez@edu.gva.es designates 193.145.201.30 as permitted sender)
smtp.mailfrom="prvs=515e510d8=pedro.martinez@edu.gva.es";
dmarc=pass (p=NONE sp=NONE dis=NONE) header.from=gva.es
```

Consultamos:

```
(kali@kali)-[~]
$ dig TXT _dmarc.edu.gva.es

;<>> DiG 9.20.18-1-Debian <>> TXT _dmarc.edu.gva.es
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NXDOMAIN, id: 38909
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1220
; COOKIE: cad0d1b7592c2e8ed993c61669a7235ec3d31ddd52f3dc2 (good)
;; QUESTION SECTION:
;_dmarc.edu.gva.es.                IN      TXT

;; AUTHORITY SECTION:
gva.es.                18      IN      SOA     ninot.gva.es. admincorreo.gva.es. 2026030301 14400 300 604800 7200

;; Query time: 68 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Mar 03 13:07:25 EST 2026
;; MSG SIZE rcvd: 128
```

No existe DMARC en edu.gva.es. Suponemos que igual que el SPF, dependerá del gva.es. Probamos:

```
(kali@kali)-[~]
$ dig TXT _dmarc.gva.es

;<>> DiG 9.20.18-1-Debian <>> TXT _dmarc.gva.es
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 38468
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1220
; COOKIE: 2b9f0c632909cf7423878bd369a723aad7f05ac4c695a136 (good)
;; QUESTION SECTION:
;_dmarc.gva.es.                IN      TXT

;; ANSWER SECTION:
_dmarc.gva.es.                5       IN      TXT     "v=DMARC1; p=none; rua=mailto:dmarc-reports@gva.es"

;; Query time: 64 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Mar 03 13:08:41 EST 2026
;; MSG SIZE rcvd: 132
```

Y aquí lo tenemos, configurado con p=none;

Observemos el DMARC de Agencia Tributaria:

```
(kali㉿kali)-[~]
$ dig TXT _dmarc.agenciatributaria.gob.es

; <<>> DiG 9.20.18-1-Debian <<>> TXT _dmarc.agenciatributaria.gob.es
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 42940
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1220
; COOKIE: 211b20b4e17c28243d0905e969a72479400a7a7a4c6f19c4 (good)
;; QUESTION SECTION:
;_dmarc.agenciatributaria.gob.es. IN      TXT

;; ANSWER SECTION:
_dmarc.agenciatributaria.gob.es. 282 IN TXT      "v=DMARC1; p=reject; fo=1; ri=3600; rua=mailto:informesdmarc@correo.aeat.es;
ruf=mailto:informesdmarc@correo.aeat.es"

;; Query time: 44 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Tue Mar 03 13:12:08 EST 2026
;; MSG SIZE rcvd: 216
```

Y observamos que tiene configurado p=reject, con lo que los correos que no pasen la autenticación DKIM y SPF serán rechazados (no llegarán al destinatario).

Como ya se ha comentado, todas estas comprobaciones solo deben realizarse si aún viendo que todo esta en orden, tenemos sospechas o necesitamos hacer un informe forense exhaustivo, si deberíamos hacer y evidenciar estas comprobaciones.

7.5.5 AUTHENTICATION RESULTS

Esta cabecera indica un resumen de las valoraciones dadas por el servidor final tras realizar las comprobaciones SPF, DKIM y DMARC

```
Authentication-Results: mx.google.com;
  dkim=pass header.i=@iestrassierra.ga header.s=dkimIDmail header.b=c3IgwJ2h;
  spf=pass (google.com: domain of moodletic@iestrassierra.ga designates 81.43.38.254 as permitted sender)
  smtp.mailfrom=moodleTic@iestrassierra.ga;
  dmarc=pass (p=REJECT sp=REJECT dis=NONE) header.from=iestrassierra.ga
```

Importancia del trabajo conjunto de los 3 protocolos:

- **SPF solo:** Valida la IP del servidor, **NO valida el contenido del mensaje**
- **DKIM solo:** Valida la integridad del mensaje, NO el dominio remitente visible
- **DMARC:** Combina SPF+DKIM + política rechazo = protección completa

Si la política de rechazo está configurada p=none, deberíamos revisar DKIM y SPF con detalle.

8 Funcionamiento de los protocolos de autenticación

Para poder analizar correctamente un correo electrónico es interesante conocer con algo más de detalle cómo funcionan los 3 protocolos explicados anteriormente:

8.1 SPF (Sender Policy Framework)

Registro DNS SPF:

```
example.com. IN TXT "v=spf1 ip4:192.0.2.0/24 ip4:198.51.100.123  
include:_spf.google.com -all"
```

Desglose:

v=spf1	→ Versión SPF 1
ip4:192.0.2.0/24	→ Rango IPs autorizadas (192.0.2.0 - 192.0.2.255)
ip4:198.51.100.123	→ IP específica autorizada
include:_spf.google.com	→ Incluir IPs autorizadas Google (Gmail business)
-all	→ Política FAIL (rechazar resto IPs)

Alternativas -all:

- ~all** → SOFTFAIL (marcar sospechoso, no rechazar)
- ?all** → NEUTRAL (no validar)
- +all** → PASS (permitir todo) ⚠ INSEGURO

Flujo validación SPF:

- Remitente envía email:
From: contacto@example.com
SMTP servidor: 192.0.2.50
- Servidor destino (Gmail, Outlook) recibe email:
 - Extrae dominio remitente: example.com
 - Extrae IP servidor origen: 192.0.2.50
- Servidor Destino realiza Query DNS SPF:
\$ dig TXT example.com → "v=spf1 ip4:192.0.2.0/24 -all"
- Validación:
¿192.0.2.50 está en rango 192.0.2.0/24? → Sí
Resultado: SPF PASS ✅

5. Si IP fuera 203.0.113.45 (no autorizada):

¿203.0.113.45 está en rango 192.0.2.0/24? → NO

Política -all → SPF FAIL ❌

Acción: Rechazar o marcar spam

8.2 Ejemplo análisis forense SPF email phishing

Email phishing suplantando banco BBVA:

Headers email:

From: seguridad@bbva.com (FALSO - spoofed)

Return-Path: <phishing@offshore-server.ru>

Received: from mail.offshore-server.ru [185.220.101.45]

Validación SPF:

1. Dominio visible: bbva.com

2. IP servidor real: 185.220.101.45 (Rusia)

3. Query DNS SPF BBVA:

\$ dig TXT bbva.com → "v=spf1 include:_spf.bbva.com -all"

\$ dig TXT _spf.bbva.com → "v=spf1 ip4:194.224.0.0/16 ip4:213.4.0.0/17 -all"

4. ¿185.220.101.45 está en rangos autorizados BBVA? → NO

Resultado: SPF FAIL ❌

Conclusión: Email NO fue enviado desde servidores autorizados BBVA

Evidencia: Phishing demostrado técnicamente

8.3 DKIM (Domainkeys Identifier Mail)

Registro DNS DKIM (clave pública):

default._domainkey.example.com. IN TXT "v=DKIM1; k=rsa;
p=MIGfMA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQC3..."

Desglose:

v=DKIM1 → Versión DKIM 1

k=rsa → Algoritmo criptográfico RSA

p=MIG... → Clave pública RSA (Base64) para verificar firma

Firma DKIM en email (header):

DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed;
d=example.com; s=default;
h=from:to:subject:date:message-id;
bh=2jUSOH9NhtVGcQWNr9BrlAPreKQjO6Sn7XlKfJVOzv8=;
b=dzdVyOfAKCdLXdJOc9G2q8LoXSlEniSbav+yuU4zGkwf8...

Desglose:

v=1	→ Versión DKIM
a=rsa-sha256	→ Algoritmo firma (RSA + SHA256 hash)
d=example.com	→ Dominio firmante
s=default	→ Selector (identifica clave pública DNS)
h=from:to:subject...	→ Headers incluidos en firma
bh=2jUSO...	→ Hash cuerpo mensaje (body hash)
b=dzdVy...	→ Firma digital completa (RSA signature)

Proceso firma y verificación DKIM:

ENVÍO (servidor remitente example.com):

1. Servidor genera hash SHA256 cuerpo email → bh=2jUSO...
2. Servidor genera hash headers seleccionados → h=from:to:subject...
3. Servidor firma hash con clave PRIVADA RSA → b=dzdVy...
4. Añade header DKIM-Signature al email
5. Envía email

RECEPCIÓN (servidor destino Gmail):

1. Extrae header DKIM-Signature
2. Identifica dominio (d=example.com) y selector (s=default)
3. Query DNS clave pública:
\$ dig TXT default._domainkey.example.com
p=MIGfMA0GCS... (clave pública RSA)
4. Recalcula hash cuerpo email actual → bh'
5. Compara bh (firma) vs bh' (recalculado):
¿bh == bh'? → SÍ = cuerpo NO modificado ✅
6. Verifica firma digital b con clave pública:
RSA_verify(b, p) → VÁLIDA ✅

Resultado: DKIM PASS ✅

Conclusión: Email íntegro, no modificado en tránsito

8.4 Ejemplo análisis forense DKIM email phishing

Email phishing suplantando AEAT (Agencia Tributaria):

Headers email:

From: notificaciones@agenciatributaria.gob.es
DKIM-Signature: v=1; a=rsa-sha256; d=phishing-domain.tk; ...

Validación DKIM:

1. Dominio firmante DKIM: phishing-domain.tk (NO agenciatributaria.gob.es)
2. Query DNS phishing-domain.tk:
 - Clave pública existe
 - Firma VÁLIDA para phishing-domain.tk

Problema: DKIM PASS para phishing-domain.tk

PERO el dominio visible (From) es agenciatributaria.gob.es (es diferente)

Resultado: DKIM alignment FAIL ❌

Conclusión: Email firmado por dominio diferente (suplantación)

⚠️ DKIM solo NO protege contra spoofing (necesita DMARC alignment)

8.5 DMARC (Domain-based Message Authentication)

Registro DNS DMARC:

_dmarc.example.com. IN TXT "v=DMARC1; p=reject; rua=mailto:dmarc-reports@example.com; ruf=mailto:dmarc-forensic@example.com; pct=100; adkim=s; aspf=s"

Desglose:

v=DMARC1 → Versión DMARC
p=reject → Política si FAIL: reject (rechazar), quarantine (spam), none (monitorizar)
rua=mailto:... → Email recibir reportes agregados (diarios)
ruf=mailto:... → Email recibir reportes forenses (cada fallo)
pct=100 → Porcentaje emails aplicar política (100 = todos)
adkim=s → DKIM alignment: s (strict), r (relaxed)
aspf=s → SPF alignment: s (strict), r (relaxed)

Políticas DMARC:

p=none → Solo monitorizar (enviar reportes, NO rechazar)
p=quarantine → Marcar spam si falla SPF/DKIM
p=reject → RECHAZAR si falla SPF/DKIM (máxima protección)

8.5.1 DMARC Alignment (alineación de dominios)

DMARC valida que el dominio visible (From header) COINCIDA con:

- Dominio SPF (Return-Path)
- Dominio DKIM (d= firma)

Ejemplo LEGÍTIMO:

From: contacto@example.com
Return-Path: <bounce@example.com>
DKIM d=example.com

SPF alignment: example.com == example.com 
DKIM alignment: example.com == example.com 
DMARC: PASS 

Ejemplo PHISHING:

From: seguridad@bbva.com
Return-Path: <phishing@offshore-server.ru>
DKIM d=offshore-server.ru
SPF alignment: bbva.com != offshore-server.ru 
DKIM alignment: bbva.com != offshore-server.ru 
DMARC: FAIL 

Política DMARC bbva.com: p=reject

Acción: Gmail/Outlook RECHAZA email antes llegar bandeja entrada

8.5.2 Flujo completo SPF + DKIM + DMARC

Email recibido:

From: contacto@example.com
Servidor origen: 192.0.2.50
DKIM firma: d=example.com, b=dzdVy...

Gmail/Outlook validación:

1. Validación SPF:

¿192.0.2.50 autorizada para example.com? → Consulta DNS SPF
Resultado: SPF PASS 

2. Validación DKIM:

¿Firma DKIM válida? → Consulta DNS clave pública + verifica firma
Resultado: DKIM PASS 

3. Validación DMARC:

Query DNS _dmarc.example.com → p=reject

¿SPF alignment OK? example.com == example.com ✓

¿DKIM alignment OK? example.com == example.com ✓

Resultado: DMARC PASS ✓

Decisión final: Email LEGÍTIMO → El correo se deposita en la Bandeja de entrada

Si SPF FAIL o DKIM FAIL:

4. DMARC política: p=reject

Decisión: RECHAZAR email (no entregar)

Enviar reporte DMARC a rua=dmarc-reports@example.com

9 Ejemplos de análisis forense SPF/DKIM/DMARC

9.1 Caso 1: Phishing AEAT - Campaña 2026 (420,000 emails)

Contexto: Campaña masiva phishing suplantando Agencia Tributaria española

Email fraudulento recibido:

```
From: notificaciones@agenciatributaria.gob.es
Subject: Devolución IRPF 2025 pendiente - €1,247 a su favor
Date: Mon, 5 Feb 2026 09:15:32 +0100

Estimado contribuyente,
Su declaración IRPF 2025 ha sido revisada. Importe devolución: €1,247
Confirme datos bancarios para transferencia:
https://aeat-devolucion[.]info/irpf2025
Plazo 72h o devolución cancelada.
Agencia Estatal de Administración Tributaria
```

Análisis headers email:

```
Return-Path: <campaign@bulk-sender.tk>
Received: from mail.bulk-sender.tk ([185.220.101.45])
  by mx.google.com with ESMTPS
From: notificaciones@agenciatributaria.gob.es
DKIM-Signature: v=1; a=rsa-sha256; d=bulk-sender.tk; s=default; ..
```

Validación SPF:

Query SPF Agencia Tributaria

```
$ dig TXT agenciatributaria.gob.es

agenciatributaria.gob.es. IN TXT "v=spf1 ip4:195.55.0.0/16
ip4:217.126.0.0/16 -all"
```

Validación:

Email enviado desde: 185.220.101.45 (bulk-sender.tk)

¿185.220.101.45 está en rangos autorizados AEAT?

195.55.0.0/16 → NO

217.126.0.0/16 → NO

Resultado: SPF FAIL ❌

Conclusión: Servidor NO autorizado por AEAT

Validación DKIM:

DKIM signature en email:

DKIM-Signature: d=bulk-sender.tk; s=default; ...

Query clave pública

```
$ dig TXT default._domainkey.bulk-sender.tk  
"v=DKIM1; k=rsa; p=MIGfMA0..."
```

Verificación firma:

Firma DKIM: VÁLIDA para bulk-sender.tk ✅

PERO:

Dominio From visible: agenciatributaria.gob.es

Dominio DKIM firmante: bulk-sender.tk

Alignment: agenciatributaria.gob.es != bulk-sender.tk ❌

Resultado: DKIM alignment FAIL ❌

Validación DMARC:

Query DMARC AEAT

```
$ dig TXT _dmarc.agenciatributaria.gob.es  
⚠️ RESULTADO: NXDOMAIN (no existe registro DMARC)
```

Conclusión CRÍTICA:

- AEAT NO tiene DMARC configurado
- Sin política rechazo (p=reject)
- Gmail/Outlook NO rechazan automáticamente email
- Email llega bandeja entrada víctimas (420,000 afectados)

Si AEAT tuviera DMARC p=reject:

1. Gmail detecta SPF FAIL + DKIM alignment FAIL
2. Consulta política DMARC → p=reject
3. RECHAZA email antes entrega
4. Víctimas NO ven email phishing
5. Daño: CERO (vs €8.3M real)

Peritaje forense presentación de evidencias:

El informe pericial debe incluir:

1. Headers email completos (raw)
2. Análisis SPF:
 - Registro SPF AEAT (DNS query captura)
 - IP servidor origen (185.220.101.45)
 - Conclusión: SPF FAIL (servidor no autorizado)
3. Análisis DKIM:
 - Firma DKIM (d=bulk-sender.tk)
 - Dominio From (agenciatributaria.gob.es)
 - Conclusión: Alignment FAIL (dominios diferentes)
4. Análisis DMARC:
 - Query DNS _dmarc.agenciatributaria.gob.es
 - Resultado: NXDOMAIN (no configurado)
 - Conclusión: Sin protección DMARC
5. Evidencia phishing:
 - URL fraudulenta: aeat-devolucion[.]info
 - WHOIS dominio: Registrado 2026-02-03 (2 días antes campaña)
 - Hosting: Offshore (Rumania)

Conclusión judicial:

- ✓ Email demostrado técnicamente NO legítimo AEAT
- ✓ Suplantación identidad probada (SPF/DKIM FAIL)
- ✓ Negligencia AEAT (sin DMARC) → responsabilidad parcial

9.2 Caso 2: BEC (Business Email Compromise) - Fraude €120K

Contexto: Atacante suplanta CEO empresa, solicita transferencia urgente

Email fraudulento recibido:

```
From: carlos.ruiz@example-corp.com (CEO real)
To: finanzas@example-corp.com
Subject: RE: Transferencia urgente - Operación China

María,

Necesito transferencia urgente €120,000 a proveedor China.
Operación confidencial, board aprobó ayer.

IBAN: ES76 0081 XXXX XXXX XXXX XXXX (cuenta mula)
Beneficiario: Shanghai Trading Ltd
Concepto: Anticipo materias primas Q1

Ejecutar antes 16:00h hoy. Llamaré mañana, ahora reunión.

Carlos Ruiz, CEO
```

Análisis headers:

```
Return-Path: <carlos.ruiz@example-corp.com> ← ⚠ Typosquatting (l en lugar de I)
Received: from mail.example-corp.com ([203.0.113.45])
From: carlos.ruiz@example-corp.com (spoofed)
```

Validación SPF:

Query SPF empresa real

```
$ dig TXT example-corp.com
```

```
"v=spf1 ip4:198.51.100.0/24 include:_spf.google.com -all"
```

Validación:

Email enviado desde: 203.0.113.45 (example-corp.com typosquatting)
¿203.0.113.45 autorizada para example-corp.com? → NO

Resultado: SPF FAIL ❌

Validación DKIM:

DKIM ausente en email fraudulento
No header DKIM-Signature encontrado

Resultado: DKIM FAIL ❌ (no firmado)

Validación DMARC:

```
# Query DMARC empresa real
$ dig TXT _dmarc.example-corp.com
```

```
⚠ RESULTADO: "v=DMARC1; p=none; rua=mailto:dmarc@example-corp.com"
```

Problema:

- DMARC configurado PERO política p=none (solo monitorizar)
- NO rechaza emails que fallan SPF/DKIM
- Email llega a la bandeja de entrada

Gmail valida:

SPF FAIL ❌ + DKIM FAIL ❌

Consulta DMARC → p=none (no hacer nada)

Acción: Entregar email (solo añade warning sutil)

Consecuencia:

- Empleada finanzas NO ve alerta clara
- Confía en remitente (parece CEO)
- Ejecuta transferencia €120,000
- Descubre fraude 24h después (irrecuperable)

Si DMARC fuera p=reject:

Gmail rechaza email automáticamente
Empleada NO ve email fraudulento
Fraude: EVITADO

10 Buscando evidencias de correos electrónicos

10.1 Microsoft Outlook PST

El cliente de correo por excelencia de sistemas Windows, es Microsoft Outlook. Todos los mensajes enviados, recibidos, contactos y calendario se almacenan en un fichero PST.

Fichero almacenado por defecto:

- **%USERPROFILE%\LocalSettings\ApplicationData\Microsoft\Outlook** (WinXP y anteriores)
- **%USERPROFILE%\AppData\Local\Microsoft\Outlook** -> Win7 / Win8 y en adelante.

La clave de registro nos puede indicar que archivos están siendo utilizados.

- **HKEY_CURRENT_USER\Software\Microsoft\WindowsNT\CurrentVersion\Windows Messagin Subsystem\Profiles\Outlook**
- **El Archivo tiene un tamaño máximo de 50 GB**

Si no se encuentra, se buscará por extensión o se realizará la técnica de recuperación de datos, ya que el fichero **PST** dispone de cabecera conocida. Se podría realizar mediante Photorec.

Herramienta para ver ficheros PST: **Kernel PST Viewer**

<https://www.nucleustechologies.com/download-outlook-pst-viewer.php>

Recuperación de adjuntos de Microsoft Outlook

Microsoft Outlook utiliza un directorio temporal seguro para abrir los adjuntos de los mensajes de correo electrónico:

- **%APPDATA%\Local\Microsoft\Windows\Temporary Internet Files\Content.Outlook - > IE10**
- **%APPDATA%\Local\Microsoft\InetCache\Content.Outlook -> IE11+**

Antes de la versión de Outlook 2007, los mensajes quedaban guardados siempre. Después de la versión de Outlook 2007 en adelante, los adjuntos están, mientras que el correo electrónico este abierto o quedaría en esa carpeta si Outlook es cerrado correctamente. pero esta vez, en vez de añadir una imagen forense vamos a añadir un fichero, en este caso el fichero MBOX.

10.2 Thunderbird MBOX

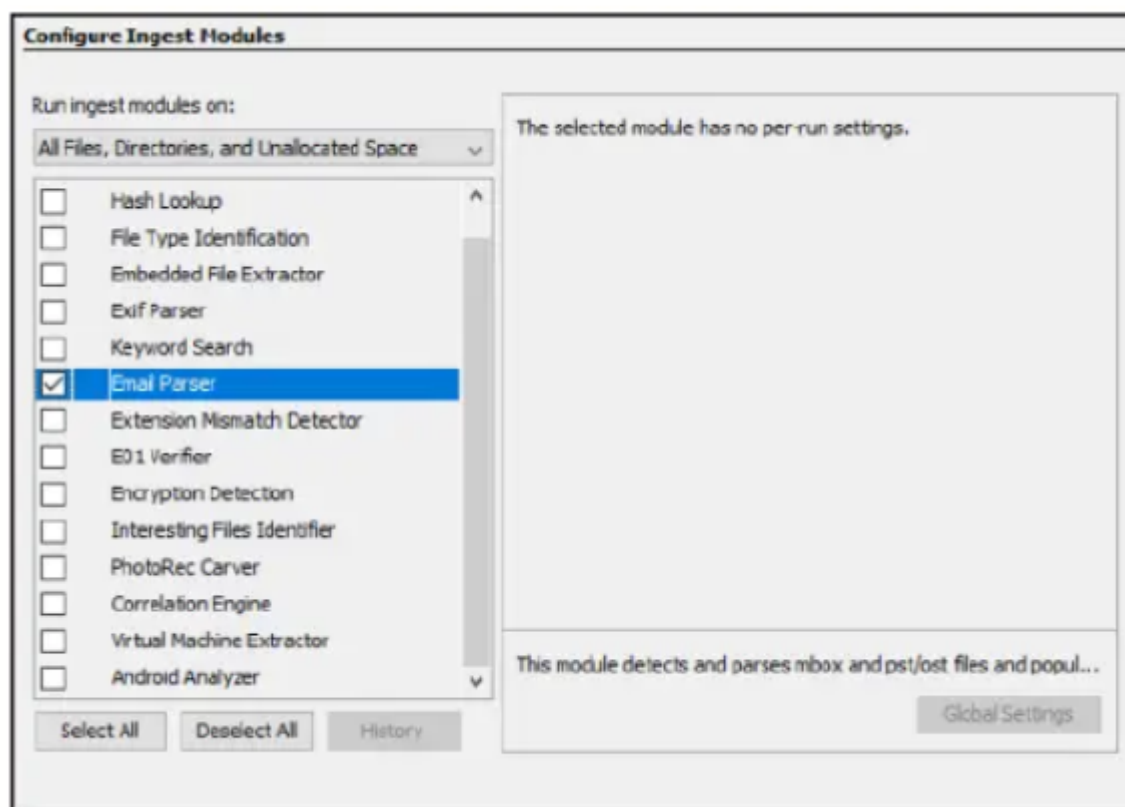
El cliente de correo Thunderbird almacena en la información en ficheros **MBOX**. Estos ficheros pueden ser encontrados en la siguiente ruta:

\Users\%USERNAME%\AppData\Roaming\Thunderbird\Profiles

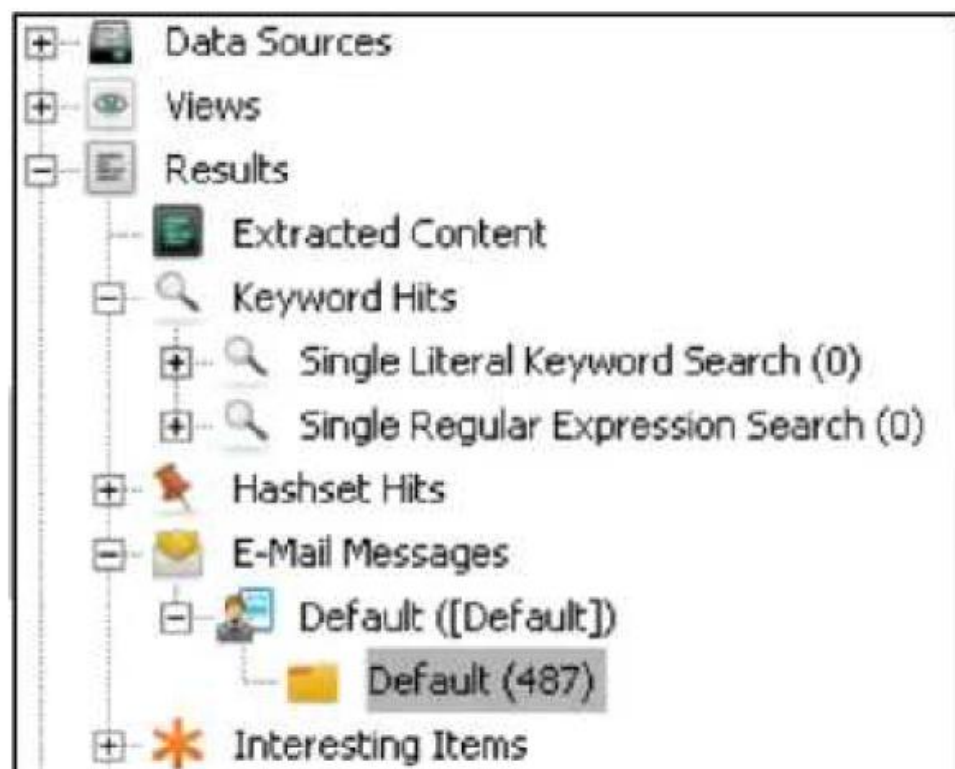
Para poder leer este fichero MBOX sin la necesidad de Thunderbird podemos recurrir a Autopsy. Crearíamos un nuevo caso, pero esta vez, en vez de añadir una imagen forense se añadirá un fichero, en este caso el fichero MBOX.



Después utilizar el ingest "Email Parser" para que pueda extraer los emails contenidos en el fichero.



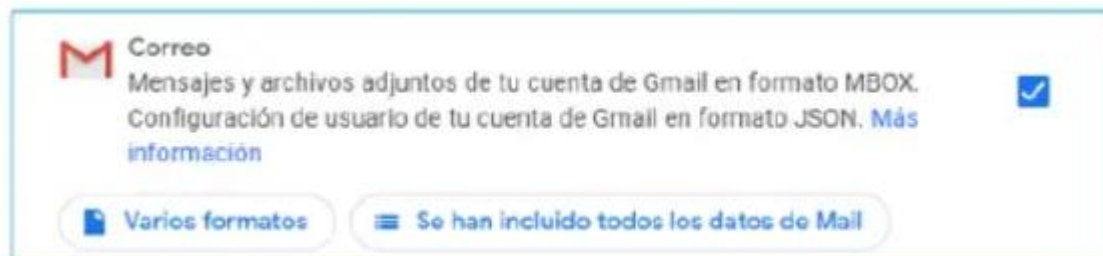
Este Modulo, es capaz también de leer ficheros **PST** y **OST**. Una vez que haya terminado de analizar el fichero MBOX se puede acceder a los correos en la siguiente sección:



10.3 Google Takeout

Google Takeout y Google Vault son comúnmente usadas para exportar la mensajería de correo electrónico para investigaciones forenses.

En el siguiente enlace se puede seleccionar que información se quiere exportar de la cuenta Google: <https://takeout.google.com/settings/takeout?pli=1>



Como se aprecia, generará un fichero MBOX con todos los mensajes de correo electrónico sin tener opción a realizar búsquedas. De hecho, cuando Google termina la exportación del Takeout, avisa mediante un correo electrónico.

Google Vault, es la bóveda donde Google almacena toda la información de una cuenta de pago o GSUITE. En Google Vault si existe la posibilidad de exportar ciertos correos electrónicos. Google Vault viene incluido en GSUITE Business and Enterprise.

Google Vault proporciona un hash MD5 de los ficheros exportados, así como un indicar del tiempo de exportación.

Google ha introducido recientemente una característica de seguridad llamada "Confidential Mode" que impide buscar correos mediante la Api de Google pero si con Google Vault.

11 Coherencia de la cabecera y los metadatos

En un análisis profundo, también es necesario estudiar la coherencia del contenido del correo, así como los posibles metadatos de los ficheros adjuntos.

11.1 Coherencia en la cabecera

Observando la cabecera podemos darlos cuenta que hay una marca de tiempo por cada servidor o intermediario por el que pasa el correo. Si observamos el ejemplo del principio de la unidad, repasando los campos Received:

```
Received: by 2002:a05:6504:1883:b0:2f1:729:b9fb with SMTP id q3csp25286011tt;
Tue, 3 Mar 2026 07:12:25 -0800 (PST)
X-Received: by 2002:a05:600c:5308:b0:483:a352:b4e4 with SMTP id 5b1f17b1804b1-48513a66cf5mr40220015e9.6.1772550744772;
Tue, 03 Mar 2026 07:12:24 -0800 (PST)
Received: from mx16.gva.es (mx16a.gva.es. [193.145.201.30])
by mx.google.com with ESMTTPS id ffacd0b85a97d-439b732d9f9si12280246f8f.467.2026.03.03.07.12.24
for <martalagarta70@gmail.com>
(version=TLS1_3 cipher=TLS_AES_256_GCM_SHA384 bits=256/256);
Tue, 03 Mar 2026 07:12:24 -0800 (PST)
Received: from mail-northeuropeazon11022118.outbound.protection.outlook.com (HELO
DUZPR83CU001.outbound.protection.outlook.com) ([52.101.66.118])
by mx16.gva.es with ESMTTP/TLS/TLS_AES_256_GCM_SHA384; 03 Mar 2026 16:12:25 +0100
```

```
ARC-Seal: i=1; a=rsa-sha256; s=arcselector10001; d=microsoft.com; cv=none;
Received: from GV1P194MB1859.EURP194.PROD.OUTLOOK.COM (2603:10a6:150:57::8) by
AS8P194MB1382.EURP194.PROD.OUTLOOK.COM (2603:10a6:20b:3c3::22) with Microsoft
SMTP Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id
15.20.9632.13; Tue, 3 Mar 2026 15:12:22 +0000
Received: from GV1P194MB1859.EURP194.PROD.OUTLOOK.COM
([fe80::5fb3:2d43:5558:a5e3]) by GV1P194MB1859.EURP194.PROD.OUTLOOK.COM
([fe80::5fb3:2d43:5558:a5e3%5]) with mapi id 15.20.9678.016; Tue, 3 Mar 2026
15:12:21 +0000
```

Observa como se deben leer los correos de abajo a arriba aplicando las diferencias horarias. En este caso el correo tarda en llegar apenas 4 segundos y las marcas de tiempo son coherentes.

11.2 Coherencia de aplicaciones

En ocasiones es posible observar en la cabecera las aplicaciones o clientes de correo que lo han tratado, como por ejemplo la etiqueta **User-Agent** o **X-Mailer**:

Esta "firma" la dejan **clientes de correo como Microsoft Outlook 16.0, Thunderbird, Apple Mail**, o incluso scripts como PHPMailer.

Aunque muchos servicios modernos (como Gmail web) ocultan esto por privacidad.

11.3 Metadatos de adjuntos

También puede ser necesario revisar la coherencia o consistencia de los metadatos o información de los ficheros adjuntos (fechas, autores, ...).

Si descargamos este [email](#) completo, podemos observar que hay un adjunto al final del correo:

```
--_004_GV1P194MB1859E8DCE78C333649345990D87FAGV1P194MB1859EURP_
Content-Type: image/jpeg; name="samsuns22_2.jpg"
Content-Description: samsuns22_2.jpg
Content-Disposition: attachment; filename="samsuns22_2.jpg"; size=41172;
    creation-date="Tue, 03 Mar 2026 15:12:15 GMT";
    modification-date="Tue, 03 Mar 2026 15:12:21 GMT"
Content-Transfer-Encoding: base64

/9j/4AAQSkZJRgABAQEASABIAAD/4QM+RXhpZgAATU0AKgAAAAgABAESAAMAAABAAEAAI.dpAAQA
AAABAAABsog1AAQAAAAABAAACaOocAAcAAAEEMAAAPgAAAAAc6gAAAAEAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
```

Podemos extraer este adjunto de diferentes formas:

De forma manual

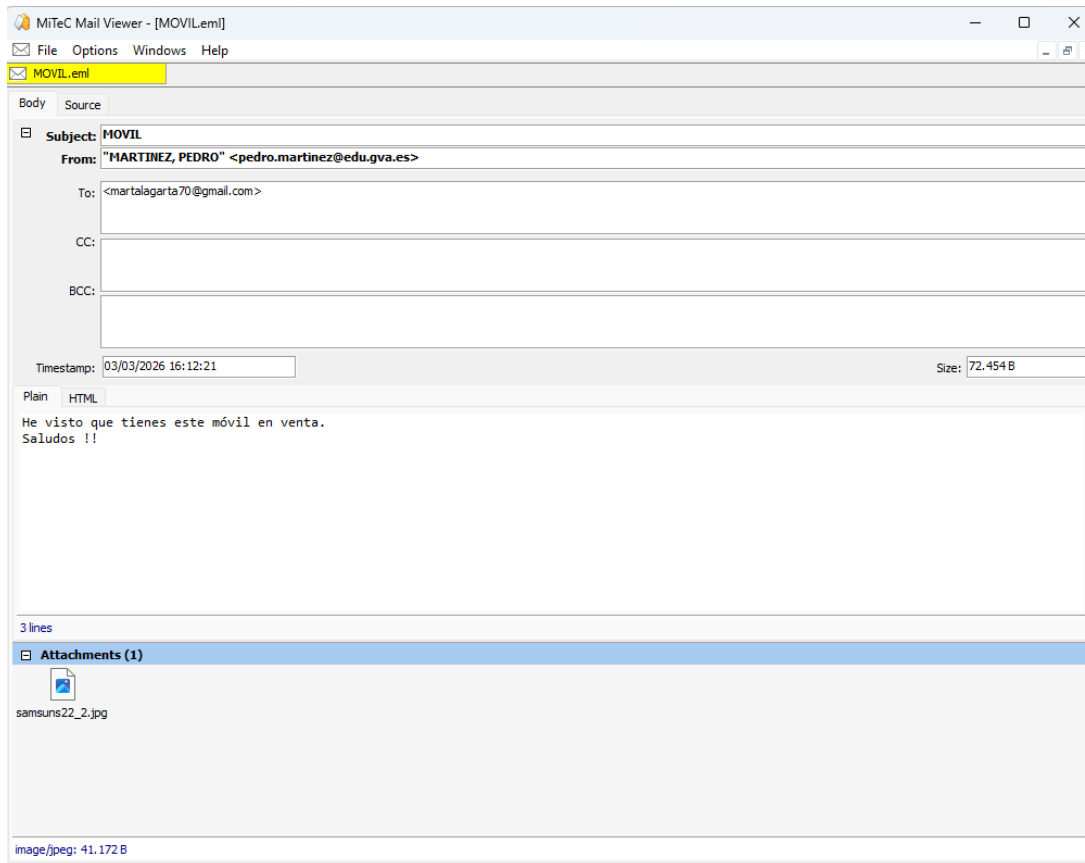
1. Copia todo ese bloque de texto codificado (el bloque Base64) y guárdalo en un archivo llamado adjunto.txt.
2. En tu terminal de Linux (Kali), ejecuta :

```
base64 -d adjunto.txt > imagen_extraida.jpg
```

Con algún software

Puedes usar un cliente correo como Microsoft Outlook para abrir el fichero eml o msg y detectará el adjunto de forma que podrás descargarlo.

También hay aplicaciones que pueden hacer lo mismo como [MiTeC Mail Viewer](#). Es un ejecutable .exe gratuito que no requiere instalación. Abres el .eml y verás una pestaña específica llamada **"Attachments"**.



12 Herramientas útiles

Las herramientas más destacadas que nos pueden ayudar son:

12.1 MXTOOLBOX

Herramientas disponibles:

SPF Record Lookup:

URL: <https://mxtoolbox.com/spf.aspx>

Input: example.com

Output:

- Registro SPF encontrado: v=spf1 ip4:192.0.2.0/24 -all
- IPs autorizadas listadas
- Errores sintaxis (si existen)
- Warnings (ej: más de 10 DNS lookups)

DKIM Record Lookup:

URL: <https://mxtoolbox.com/dkim.aspx>

Input: Dominio + selector (ej: default._domainkey.example.com)

Output:

- Clave pública RSA
- Algoritmo (rsa, ed25519)
- Validez registro

DMARC Record Lookup:

URL: <https://mxtoolbox.com/dmarc.aspx>

Input: example.com

Output:

- Política DMARC (none, quarantine, reject)
- Alineación (strict, relaxed)
- Emails reportes (rua, ruf)
- Score seguridad (0-100)

Email Headers Analyzer:

URL: <https://mxtoolbox.com/emailheaders.aspx>

Input: Headers email completos (raw)

Output:

- Resultado SPF (PASS/FAIL)
- Resultado DKIM (PASS/FAIL)
- Resultado DMARC (PASS/FAIL)
- Ruta email (servidores intermedios)

12.2 DMARCIAN (Análisis DMARC avanzado)

Herramientas disponibles:**DMARC Inspector:**

URL: <https://dmarcian.com/dmarc-inspector/>

Funciones:

- Validación sintaxis DMARC
- Recomendaciones mejora política
- Simulación enforcement (qué pasaría con p=reject)

DMARC Reports Analyzer:

URL: <https://dmarcian.com/xml-to-human-converter/>

Funciones:

- Procesa reportes XML DMARC (rua)
- Dashboard visual: fuentes email legítimas vs fraudulentas
- Identifica servidores no autorizados enviando email tu dominio
- Recomendaciones SPF/DKIM fixes

12.3 Google Admin Toolbox (toolbox.googleapps.com)

Herramienta disponible → Messageheader (Google)::

URL: <https://toolbox.googleapps.com/apps/messageheader/>

Funciones: Analiza headers email Gmail

Output:

- SPF resultado + IP origen
- DKIM resultado + firma verificada
- DMARC resultado + política aplicada
- Delays entrega (latencia servidores)
- Ruta completa email (hops)

Ideal para:

- Debugging entregas Gmail
- Análisis phishing recibido Gmail
- Verificar configuración SPF/DKIM propia